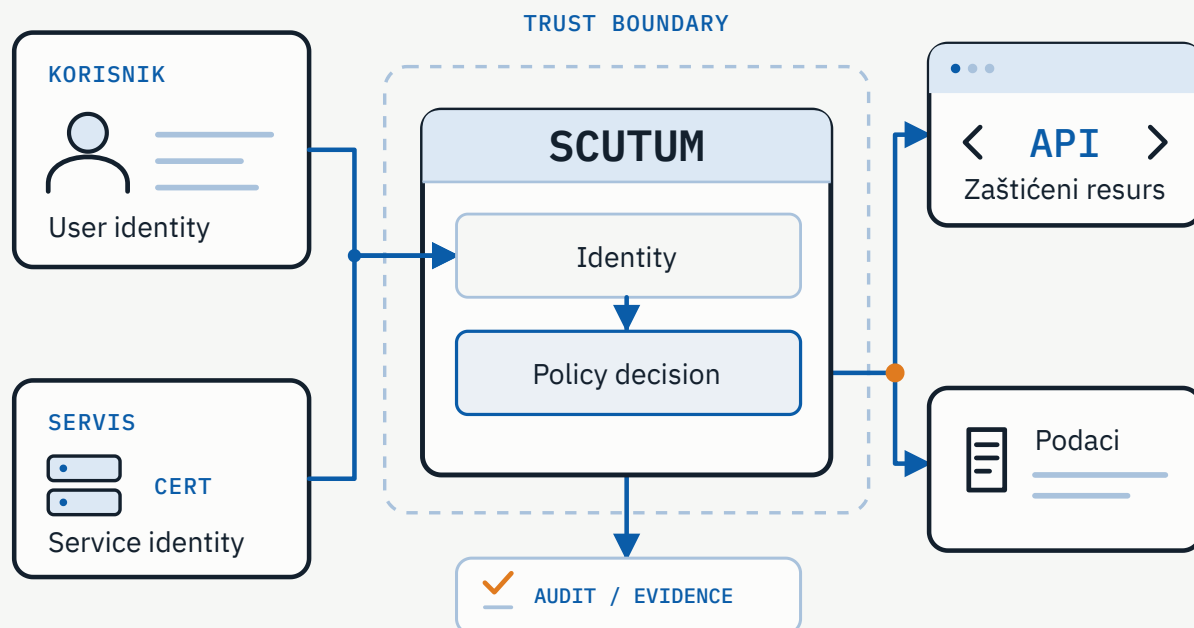


SCUTUM

Platforma za upravljanje informacionom bezbednošću i
digitalnim poverenjem



IDENTITET

KONTROLE PRISTUPA

AUDIT I DOKAZI

Sadržaj

Pregled poglavlja, opštih zahteva i 90 projektnih celina.

-	Osnovni podaci i normativne konvencije	03
01	Svrha, cilj i granice projekta	05
02	Kontekst sistema i korisnici	07
03	Bezbednosni model sistema	09
04	Razvojni nivoi i dodela projektnih celina	11
05	Opšti tehnički i procesni zahtevi	12
06	Ključni bezbednosni tokovi i threat model	17
07	Projektne celine nivoa R1	27
08	Projektne celine nivoa R2	48
09	Projektne celine nivoa R3	69
10	Integracija, bezbednosno testiranje i kriterijumi završetka	90
11	Predaja, dokumentacija i kriterijumi ocenjivanja	92
12	Rečnik ključnih pojmova	94

Oznake R1-01 do R3-30 predstavljaju stabilne identifikatore projektnih celina. Pregled celina sadrži linkove i brojeve stranica za direktan pristup njihovoj specifikaciji.

Osnovni podaci i konvencije

Osnovni podaci

Stavka	Vrednost
Naziv projekta	SCUTUM - Platforma za upravljanje informacionom bezbednošću i digitalnim poverenjem
Predmet	Osnove informacione bezbednosti
Tip rada	Timski razvoj zajedničkog bezbednosnog softverskog proizvoda
Veličina tima	6-10 studenata
Broj projektnih celina	90 (30 na nivou R1, 30 na nivou R2 i 30 na nivou R3)
Tipičan obim izvođenja	približno 200 studenata; broj timova zavisi od formirane veličine timova
Referentna tehnologija	.NET / C#; druge tehnologije uz odobrenje i dokaz interoperabilnosti
Organizacija rada	Git, feature grane, Pull Request, code review, CI i Tapiz Boards
Arhitektonski principi	Clean Architecture, SOLID, least privilege, explicit trust boundaries, testabilnost i auditabilnost

Normativne konvencije i sledljivost

Specifikacija koristi sledeća normativna značenja kako bi se smanjila mogućnost različitog tumačenja zahteva:

- **mora / nije dozvoljeno** - obavezan zahtev; neispunjenje znači da zahtev nije realizovan;
- **treba / očekuje se** - podrazumevano očekivanje koje može biti odstupanje samo uz obrazloženu i dokumentovanu odluku;
- **može / moguće proširenje** - opciono; nije deo minimalnog scope-a osim ako ga nastavni tim eksplicitno dodeli;
- **obavezni use-case** - ponašanje koje mora biti demonstrabilno i pokriveno odgovarajućim testovima;
- **ključna poslovna / bezbednosna pravila** - invariants/ograničenja koja implementacija mora sačuvati nezavisno od UI-a i tehničkog rešenja.

Sledljivost zahteva

- oznaka projektne celine, npr. `R2-05`, predstavlja stabilan identifikator njenog funkcionalnog i bezbednosnog scope-a;
- zahtevi u Tapis-u, testovima, ADR zapisima i Pull Request opisima treba da referenciraju oznaku celine i konkretan use-case ili bezbednosno pravilo;
- za cross-team i sistemske zahteve koriste se eksplicitni identifikatori oblika `SEC-<oblast>-NN`, navedeni u ovoj specifikaciji;
- jednom objavljen identifikator se ne koristi za drugo značenje; promena semantike zahteva evidentira se kroz kontrolisanu reviziju specifikacije;
- breaking promena javnog ugovora, security događaja ili policy semantike mora imati sledljiv Tapis task, review pogođenih timova i ažurirane contract/security testove.

Svrha, cilj i granice projekta

SCUTUM je informacijski sistem namenjen upravljanju identitetima, pristupom, bezbednosnim politikama, tajnama, bezbednosnim događajima, incidentima, rizicima i dokazima u organizaciji koja koristi veći broj aplikacija, servisa i informacionih resursa. Bezbednost nije dodatna funkcionalnost sistema, već osnovni domen projekta.

Projekat je defanzivno orijentisan. Ne zahteva razvoj eksploita, malvera niti napad na realne sisteme. Situacije koje predstavljaju sumnjivu aktivnost, grešku konfiguracije ili pokušaj nedozvoljenog pristupa reprodukuju se kontrolisanim simulatorima i testnim identitetima.

CILJ PROJEKTOG OKVIRA.

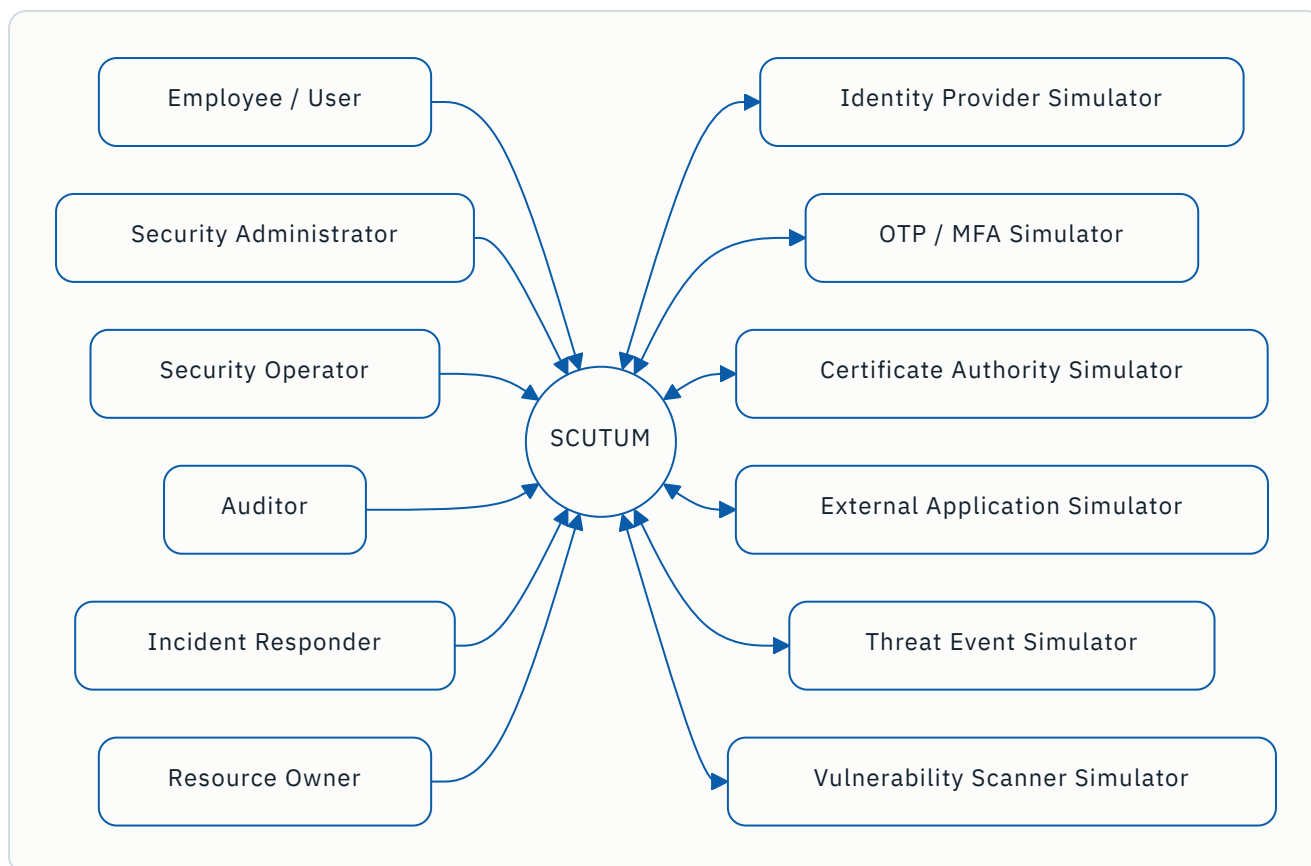
Student treba da razume vezu između asset-a, identiteta, trust granice, pretnje, kontrole, bezbednosnog testa i audit dokaza. Implementacija kontrole bez jasnog bezbednosnog zahteva i testa ne smatra se završenim rešenjem.

1.1. Obuhvat

- identity lifecycle, autentikacija i sesije;
- RBAC, object-level i policy-based autorizacija;
- multi-factor i step-up autentikacija;
- privileged access i just-in-time prava;
- service identities;
- secrets, certificate i key lifecycle;
- klasifikacija podataka i zaštita resursa;
- security audit, događaji, detekcija i alerting;
- security incident, istraga, evidence i response;
- vulnerability i dependency risk registry;
- threat modeling, risk management i access review;
- security policies, exceptions i compliance evidence;
- automatizovani negativni i bezbednosni testovi.

1.2. Van obuhvata

- napad na stvarne organizacione ili javne sisteme;
- izrada malware-a, ransomware-a, phishing infrastrukture ili eksploita;
- implementacija sopstvenih kriptografskih algoritama;
- čuvanje realnih lozinki, tajni ili produkcionih sertifikata u studentskom okruženju;
- predstavljanje simulatora kao realnog IDS/SIEM/CA proizvoda;
- formalna pravna/compliance sertifikacija organizacije.



Slika 1. Kontekst sistema SCUTUM: korisnici i spoljni bezbednosni simulatori.

Kontekst sistema i korisnici

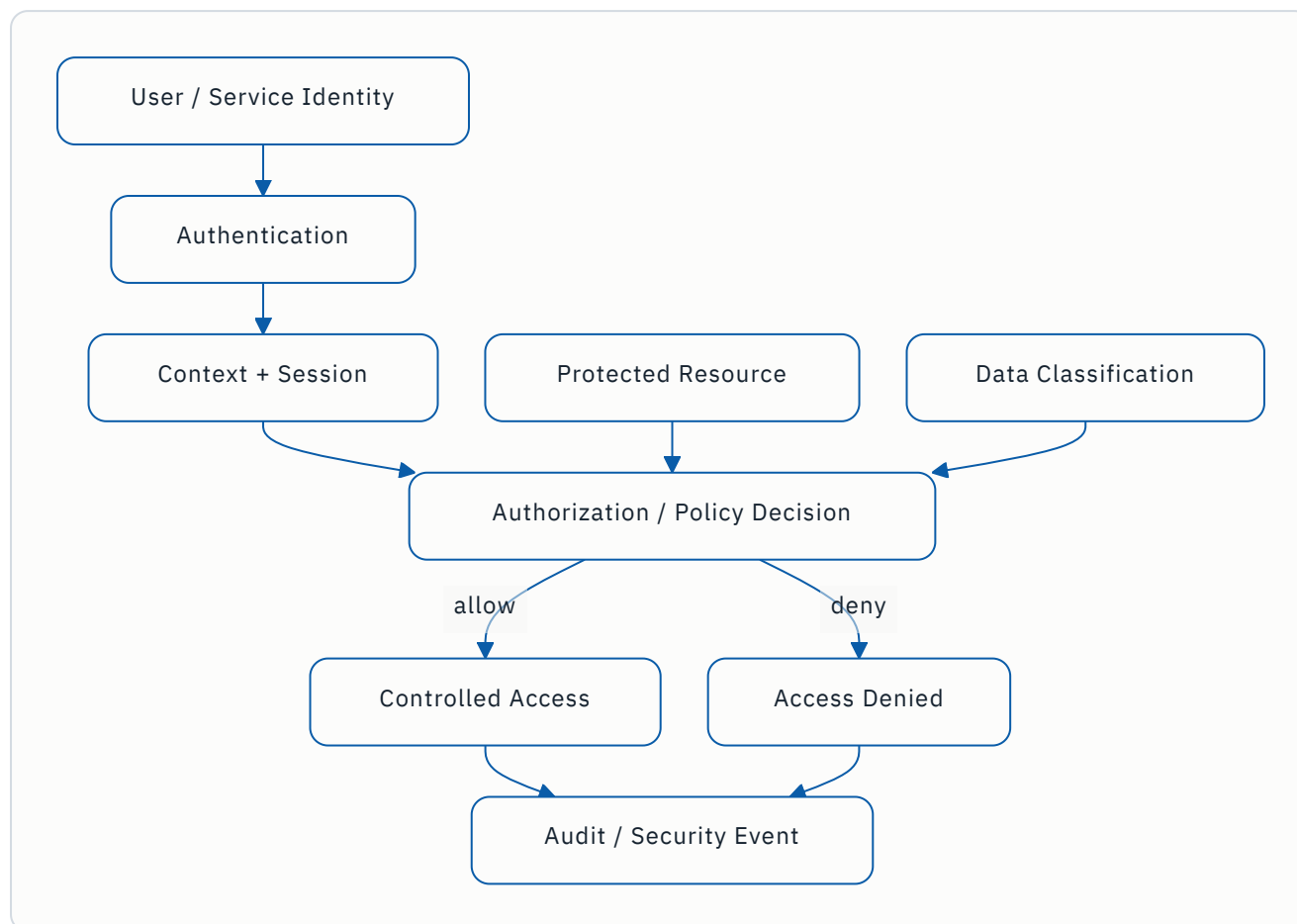
SCUTUM se posmatra kao centralna bezbednosna platforma koja održava identitete, politike, asset podatke i bezbednosne događaje za više aplikacija i organizacionih domena. Spoljni sistemi komuniciraju preko eksplicitnih adaptera ili simulatora.

2.1. Primarne uloge

Uloga	Tipične odgovornosti
Employee / User	koristi zaštićene resurse u okviru dodeljenih prava
Resource Owner	određuje vlasništvo, klasifikaciju i odobrava određene pristupe
Security Administrator	politike, identity/security konfiguracija i privilegovane promene
Security Operator / Analyst	security events, alerts, triage i nadzor
Incident Responder	istraga, containment, recovery i post-incident review
Auditor / Read-only Operator	kontrolisan pregled audit-a, evidence-a i compliance dokaza

2.2. Trust granice

Za svaki značajan tok mora biti jasno gde se identitet potvrđuje, gde se donosi odluka o pristupu, ko je vlasnik zaštićenog resursa i koje informacije prelaze granicu između komponenti.



Slika 2. Pojednostavljen model donošenja odluke o pristupu.

2.3. Simulatori

Simulator	Primer ponašanja
Identity Provider Simulator	uspešna/neuspešna autentikacija, external identity
OTP / MFA Simulator	challenge, validan/nevalidan kod, timeout
Certificate Authority Simulator	izdavanje, obnova i revocation sertifikata
External Application Simulator	pozivi ka zaštićenom API-ju i service identity scenario
Threat Event Simulator	neuspešne prijave, suspicious access, privilegovana operacija
Vulnerability Scanner Simulator	kontrolisani nalazi vezani za testne asset-e

Bezbednosni model sistema

SCUTUM ne polazi od pretpostavke da je korisnik, servis ili mrežna lokacija pouzdana samo zato što je uspešno prošla jedan prethodni korak. Svaka značajna operacija mora imati jasan identitet, scope i odluku o pristupu.

3.1. Osnovna pravila

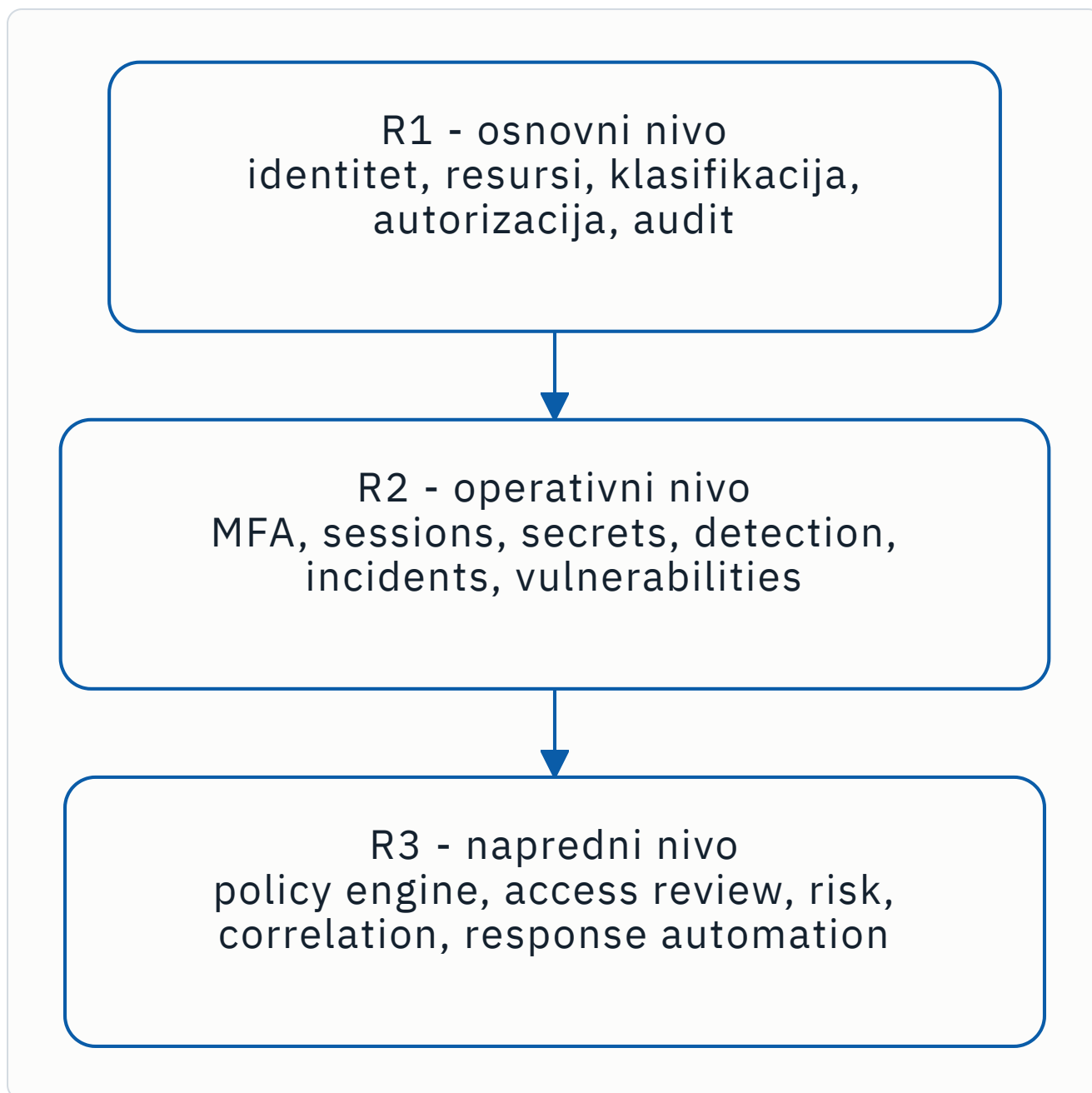
- least privilege i need-to-know gde su relevantni;
- deny-by-default za osetljive operacije gde nije eksplicitno dozvoljeno;
- autentikacija i autorizacija su odvojene odgovornosti;
- validan token ne znači automatski pristup svakom resursu;
- object-level authorization proverava se serverski;
- privilegovani pristup treba da bude ograničen scope-om i vremenom;
- tajne se ne čuvaju u source code-u ili logovima;
- standardne proverene kriptografske biblioteke se koriste umesto sopstvenih algoritama;
- bezbednosna odluka mora biti proverljiva testom i audit događajem gde je značajno.

3.2. Bezbednosni tok kao dokaz

Svaka projektna celina treba da može da pokaže sledeći lanac kada je primenljiv:

BEZBEDNOSNI TOK KAO DOKAZ

Asset -> Threat / Misuse -> Security Requirement -> Control -> Security Test -> Evidence



Slika 3. Razvojni nivoi projektnih celina; oznake predstavljaju funkcionalne preduslove.

Razvojni nivoi i dodela projektnih celina

Oznake R1, R2 i R3 predstavljaju funkcionalne preduslove i zrelost projektne celine. Ne predstavljaju akademsku godinu i ne daju studentima pravo da samostalno izaberu temu. Celine dodeljuje nastavni tim.

Nivo	Značenje	Tipični sadržaj
R1 - Osnovni	postavlja asset, identity, authorization, policy i audit temelje	identiteti, resursi, RBAC, klasifikacija, audit, baseline
R2 - Operativni	uvodi aktivne zaštitne i operative bezbednosne procese	MFA, sessions, secrets, detection, incidents, vulnerabilities
R3 - Napredni	uvodi složenije policy, risk i response tokove	ABAC/policy engine, access review, risk, correlation, response automation

DODELA PROJEKTNIH CELINA.

Tim može razvijati novu celinu, proširivati postojeću ili bezbednosno refaktorisati postojeće rešenje. Nastavni tim može ranije aktivirati R2/R3 celinu ako su njeni preduslovi dostupni ili kontrolisano simulirani.

4.1. Timovi

Tim ima 6-10 studenata. Jedna projektna celina predstavlja primarnu odgovornost tima, a velika celina može se podeliti na jasno razdvojene epike ako broj timova to zahteva.

Svaki tim treba da demonstrira kombinaciju:

- nove ili izmenjene funkcionalnosti;
- najmanje jednog negativnog/abuse scenarija;
- automatizovanog bezbednosnog testa;
- najmanje jedne cross-team trust granice kada je domen to zahteva; kada tim smatra da značajna integracija nije primenljiva, razlog mora biti eksplicitno potvrđen sa nastavnim timom;
- threat model-a svoje celine;
- refaktorisanja ako postojeći dizajn onemogućava bezbednu implementaciju.

Opšti tehnički i procesni zahtevi

5.1. Tehnološki okvir

Podrazumevana i preporučena tehnologija je .NET / C#. Druga tehnologija može biti odobrena kada tim obezbedi interoperabilnost i ekvivalentan nivo testiranja i bezbednosne kontrole.

5.2. Arhitektura i bezbedan dizajn

- Clean Architecture ili ekvivalentno jasno razdvajanje domena, use-case sloja i infrastrukture;
- SOLID tamo gde smanjuje spregnutost i olakšava testiranje;
- auth/authz, secrets i audit ne smeju biti razbacani ad-hoc kroz kod;
- značajne trust granice moraju biti eksplicitne;
- bezbednosno kritične odluke dokumentuju se kratkim ADR zapisom;
- sopstveni crypto/password/token algoritmi nisu dozvoljeni;
- hard-coded credential-i i tajne nisu prihvatljivi.

5.3. Threat model po timu

Minimalni threat model mora sadržati:

Element	Primer
Asset	korisnička sesija, tajna, dokument, privilegovana uloga
Threat / misuse	krađa sesije, horizontalni pristup, neovlašćena promena privilegije
Control	step-up, object authorization, revocation, audit
Test	negativni authorization test, expired/revoked credential test
Evidence	rezultat testa, audit događaj, konfiguracioni dokaz

5.4. Testiranje

Framework zavisi od tehnologije: NUnit/Moq za .NET, Vitest/Jest za TypeScript ili ekvivalentan alat.

- unit testovi policy i poslovnih pravila;
- integration testovi authentication/authorization adaptera;
- object-level negative testovi;
- testovi isteka/revocation-a;
- testovi tenant/scope izolacije gde postoji;
- testovi security event/audit ishoda;

- regression test za stvarno otkriven bezbednosni problem kada je moguće.

5.5. Git, Pull Request i Tapiz Boards

TOK RADA

Tapiz task -> feature branch -> commits -> Pull Request -> CI + review -> VERIFY / SECURITY QA -> DONE

- direktan push na main nije dozvoljen;
- security requirement i acceptance kriterijumi moraju biti vidljivi u task-u;
- promena auth/authz ugovora zahteva review pogođenih timova;
- CI izvršava build, testove i relevantne security checks;
- tajne ne smeju biti commit-ovane u repozitorijum.

5.6. Definition of Done

- funkcionalni acceptance kriterijumi su ispunjeni;
- threat/misuse scenario je definisan;
- kontrola je implementirana i objašnjiva;
- najmanje jedan negativni security scenario je testiran;
- audit/security event postoji gde je relevantno;
- tajne i osetljivi podaci nisu izloženi;
- CI prolazi;
- PR je pregledan;
- dokumentacija, javni ugovori i ADR su ažurirani;
- accepted cross-team ugovor, security event ili policy granica imaju owner-a, consumer-e i odgovarajući contract/security test;
- lokalno okruženje, migracije i seed/demo podaci mogu se ponovljivo pokrenuti po dokumentovanom postupku;
- tenant/scope-aware celina ima najmanje jedan negativni automatizovani test koji pokušava nedozvoljen pristup tuđem resursu;
- tim može objasniti residual risk ili poznato ograničenje.

5.7. Zajedničke tehničke i bezbednosne konvencije

Sledeća pravila važe na granicama između projektnih celina. Ona ne propisuju konkretan framework, bazu ili transportni protokol, već zajednički jezik koji smanjuje slučajne integracione i bezbednosne propuste.

SEC-CONV-01	identifikatori izloženi preko javnog ugovora moraju imati dokumentovan tip, format i pravilo jedinstvenosti; consumer ne sme zavisiti od internog načina generisanja ID-a;
SEC-CONV-02	identitet subjekta, tenant/security domen, scope i assurance level moraju biti eksplicitni u aplikacionom kontekstu svake security odluke;

SEC-CONV-03	očekivani bezbednosni neuspeh mora imati stabilan mašinski prepoznatljiv kod/vrstu i čitljivu poruku; consumer ne sme parsirati proizvoljan tekst greške;
SEC-CONV-04	security event mora imati minimalno: vreme, actor/service identity, akciju, target, ishod, korelacioni identifikator i klasifikaciju osetljivosti;
SEC-CONV-05	tajne, tokeni i credential vrednosti nikada nisu deo javnog DTO-a, loga, audit detalja ili demo seed-a;
SEC-CONV-06	kolekcionni API/ugovori koji mogu rasti moraju definisati ograničenje veličine odgovora i, gde je relevantno, pagination/filter semantiku;
SEC-CONV-07	breaking promena javnog DTO/event/contract modela zahteva novu kompatibilnu verziju, migracioni period ili koordinisanu promenu svih aktivnih consumer-a;
SEC-CONV-08	operacije koje mogu biti bezbedno ponovljene treba da imaju definisanu idempotency semantiku; duplirana poruka ne sme nekontrolisano duplirati security efekat;
SEC-CONV-09	konkurentne izmene privilegija, policy-ja, tajni ili incident statusa moraju imati definisanu strategiju konflikta;
SEC-CONV-10	vlasnik projektna celine upravlja svojim persistence modelom i migracijama; druga celina ne menja njegove tabele bez dogovorene cross-team promene.

5.8. Životni ciklus javnih ugovora i security događaja

Javni ugovor je API, event/message schema, policy decision format, evidence format ili drugi formalni oblik komunikacije koji koristi druga projektna celina.

ŽIVOTNI CIKLUS JAVNOG UGOVORA

DRAFT -> ACCEPTED -> DEPRECATED -> RETIRED

SEC-CONTRACT-01	svaki javni ugovor ima jasno navedenog owner-a i poznate consumer-e;
SEC-CONTRACT-02	stanje DRAFT može da se menja bez kompatibilnosti samo dok ga nijedan drugi tim ne koristi kao prihvaćenu granicu;
SEC-CONTRACT-03	prelazak u ACCEPTED zahteva najmanje jedan reprezentativan contract/security test ili drugi izvršiv dokaz dogovorene semantike;
SEC-CONTRACT-04	breaking promena ACCEPTED ugovora zahteva koordinaciju sa pogođenim consumer-ima pre merge-a;
SEC-CONTRACT-05	DEPRECATED ugovor ostaje podržan tokom dogovorenog migracionog perioda; razlog i zamena moraju biti dokumentovani;
SEC-CONTRACT-06	RETIRED ugovor se uklanja tek kada nema aktivnih consumer-a ili kada je nastavni tim eksplicitno odobrio koordinisano uklanjanje.

5.9. Rad sa nedostupnim preduslovima

Projektna celina višeg nivoa može početi pre pune implementacije preduslova samo ako je granica kontrolisano simulirana.

SEC-DEP-01	owner zavisne celine dokumentuje minimalni contract koji očekuje od nedostupnog preduslova;
SEC-DEP-02	simulator/stub mora podržati najmanje normalan ishod i relevantne negativne/failure ishode potrebne za razvoj;
SEC-DEP-03	simulator ne sme sadržati security logiku koja pripada upstream celini; on samo reprodukuje dogovoreno spoljašnje ponašanje;
SEC-DEP-04	kada stvarna implementacija postane dostupna, isti contract/security testovi treba da mogu da se izvrše nad stvarnim adapterom ili odgovarajućim integracionim okruženjem;
SEC-DEP-05	razlika između simulatora i stvarne implementacije tretira se kao integracioni problem i mora biti rešena pre zatvaranja zavisne celine.

5.10. Bezbednosni acceptance baseline

SEC-BASE-01	authorization se proverava serverski/aplikaciono na svakoj operaciji koja menja ili čita zaštićen resurs;
SEC-BASE-02	tenant/scope-aware celina mora imati automatizovan negativni test koji dokazuje da korisnik jednog scope-a ne može pristupiti resursu drugog scope-a samo poznavanjem identifikatora;
SEC-BASE-03	privilegovane i administrativne promene moraju proizvesti audit/security event sa identitetom izvršioca i relevantnim kontekstom;
SEC-BASE-04	tajne, tokeni i kredencijali ne smeju biti commit-ovani u repozitorijum niti hard-coded u izvorni kod;
SEC-BASE-05	ulazi koji utiču na security odluke, persistence ili audit moraju biti validirani na odgovarajućoj aplikacionoj granici;
SEC-BASE-06	odgovor prema consumer-u ne sme izlagati interne podatke drugog security domena ili tehničke detalje koji nisu deo javnog ugovora;
SEC-BASE-07	stvarni napad, exploit, phishing infrastruktura, malware ili rad nad realnim spoljnim sistemom nisu deo projekta.

5.11. Operativni i NFR baseline

Ovi zahtevi nisu industrijski SOC/SIEM benchmark; cilj je da zajednički studentski proizvod bude ponovljiv, dijagnostikabilan i održiv.

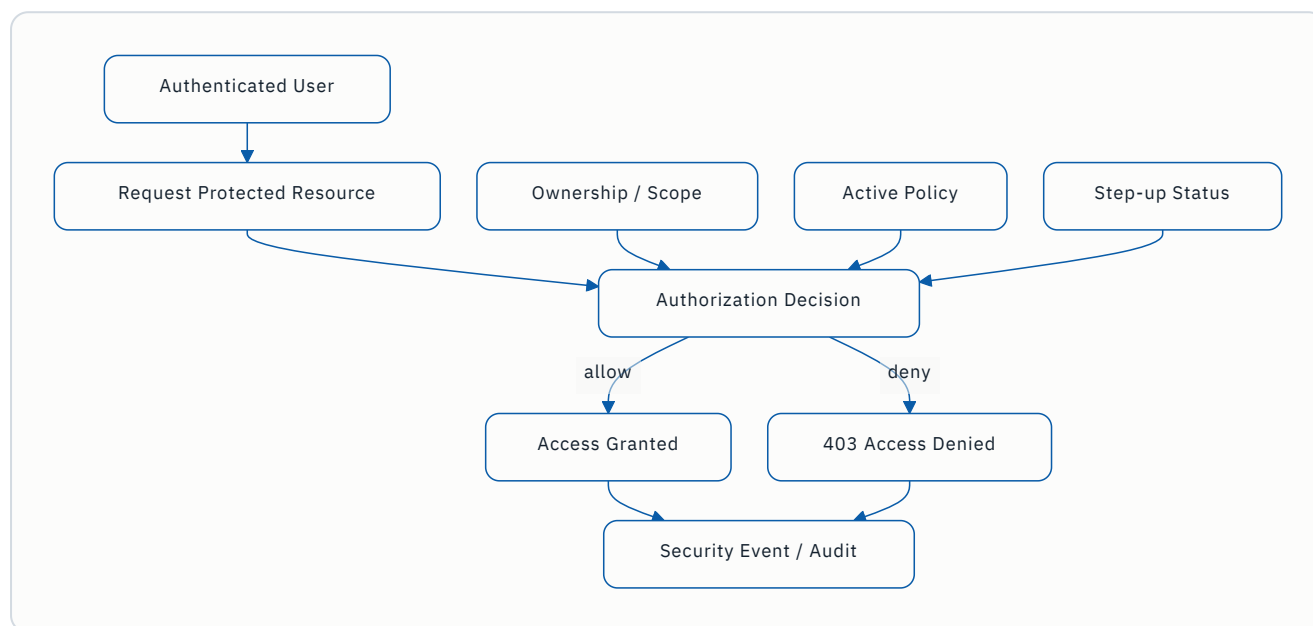
SEC-OPS-01	clean clone repozitorijuma mora moći da se build-uje i pokrene po dokumentovanom postupku bez ručnih koraka poznatih samo jednom članu tima;
SEC-OPS-02	migracije moraju moći da formiraju potrebnu šemu nad praznom bazom ili drugim čistim persistence okruženjem;

SEC-OPS-03	seed/demo podaci moraju omogućiti ponovljiv prikaz normalnog i negativnog bezbednosnog scenarija;
SEC-OPS-04	aplikacija i adapteri moraju emitovati dovoljno strukturisanih log informacija da se može pratiti neuspešan security tok bez debugger-a na računaru autora;
SEC-OPS-05	eksterni pozivi moraju imati razumno ponašanje pri timeout-u/nedostupnosti; failure spoljnog simulatora ne sme proizvesti nekontrolisano nekonzistentno security stanje;
SEC-OPS-06	konfiguracija okruženja mora biti odvojena od koda i bez tajni u repozitorijumu;
SEC-OPS-07	CI mora proveriti build, testove i statičke provere na način koji ne zavisi od lokalnog IDE okruženja.

Ključni bezbednosni tokovi i threat model

6.1. Pristup zaštićenom resursu

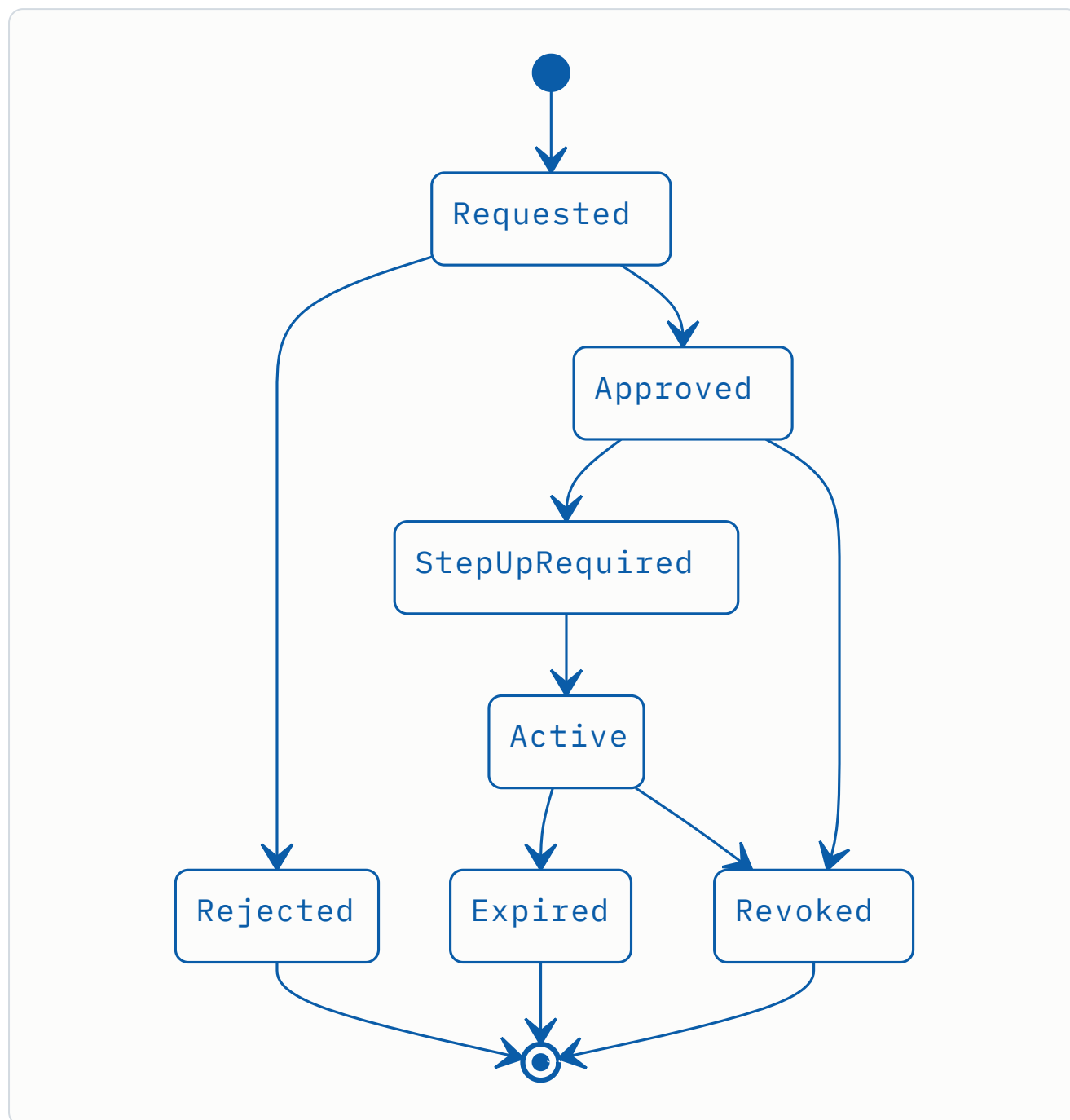
Autentikovan korisnik ne dobija automatski pravo pristupa konkretnom objektu. Odluka mora uzeti u obzir ownership/scope, aktivnu politiku i eventualni step-up zahtev.



Slika 4. Referentni tok pristupa zaštićenom resursu.

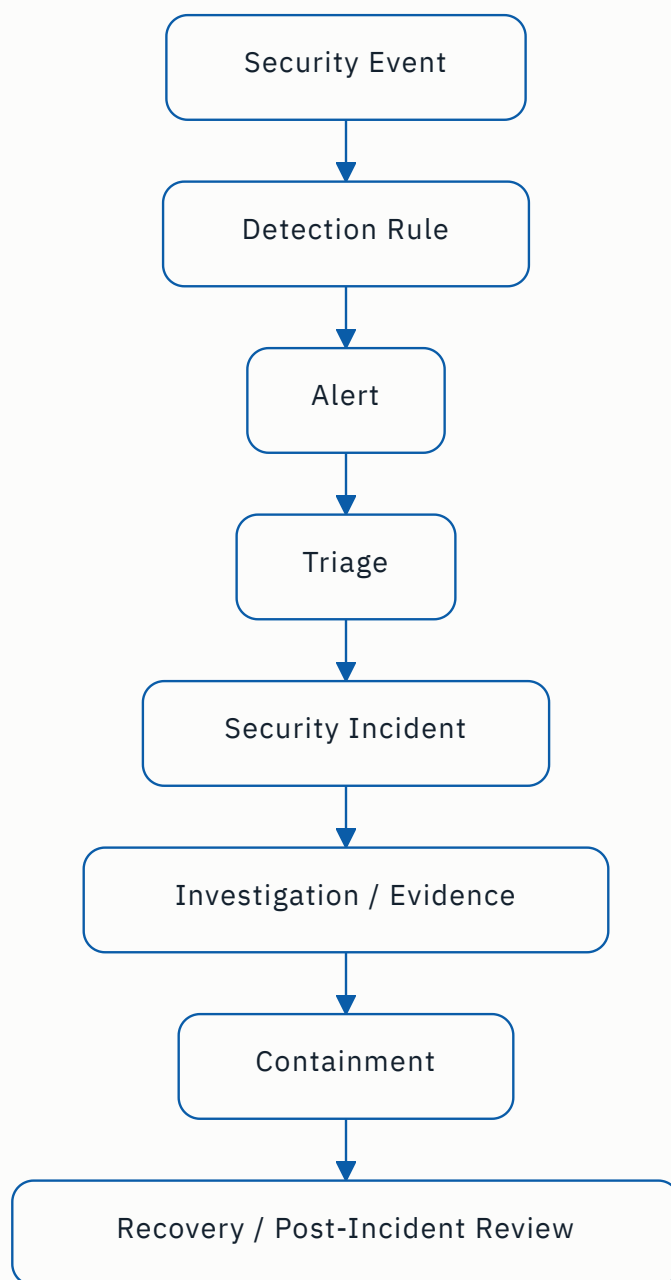
6.2. Privilegovani pristup

Privilegovana prava predstavljaju poseban rizik i treba da budu eksplicitno zahtevana, odobrena, dodatno potvrđena i vremenski ograničena.



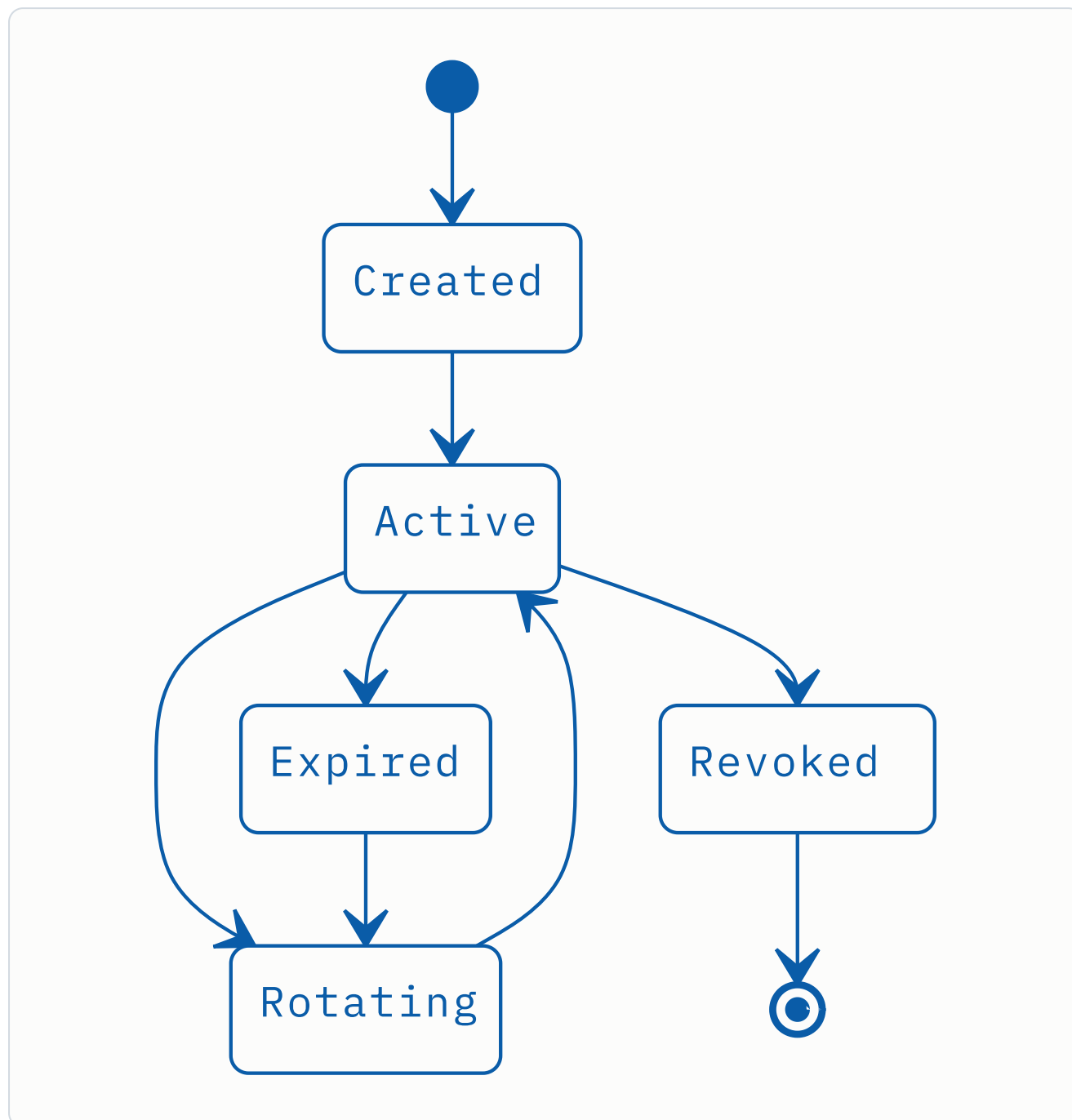
Slika 5. Pojednostavljen životni ciklus privilegovanog pristupa.

6.3. Bezbednosni događaj i incident



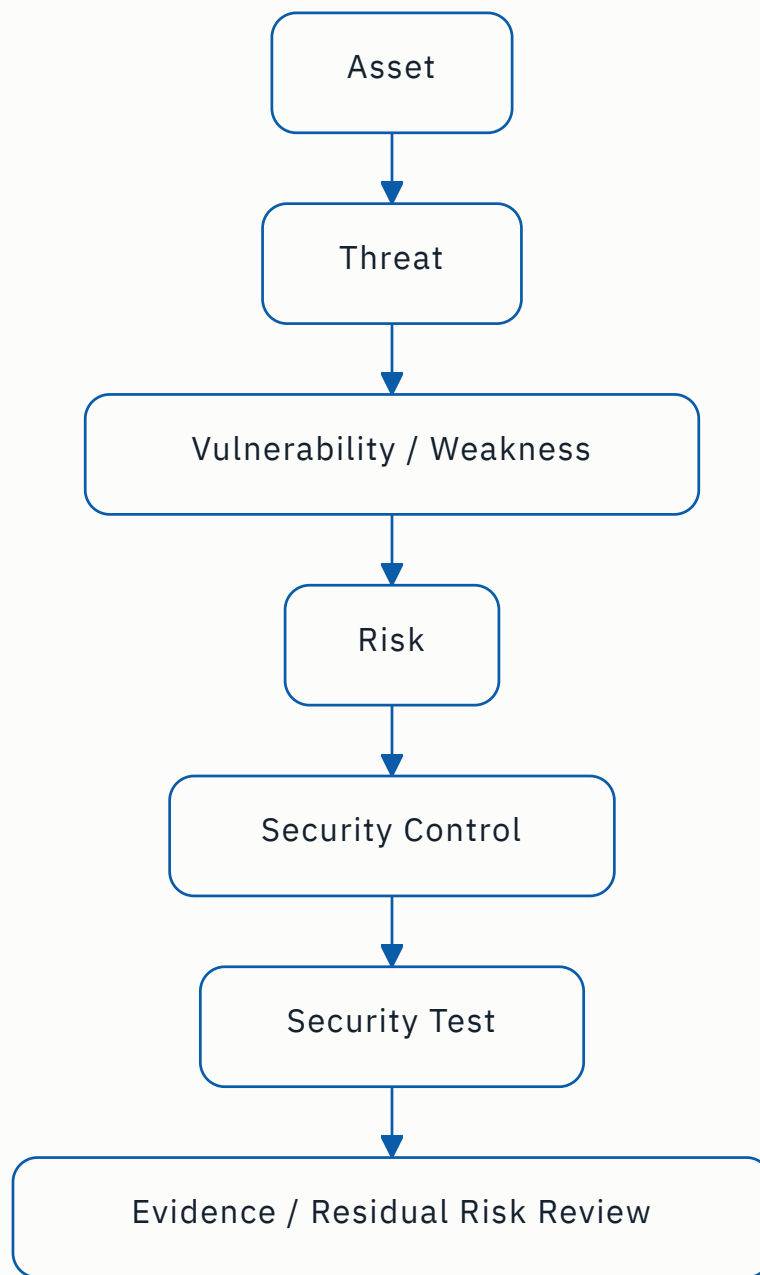
Slika 6. Veza bezbednosnog događaja, detekcije, incidenta i oporavka.

6.4. Tajna ili servisni kredencijal



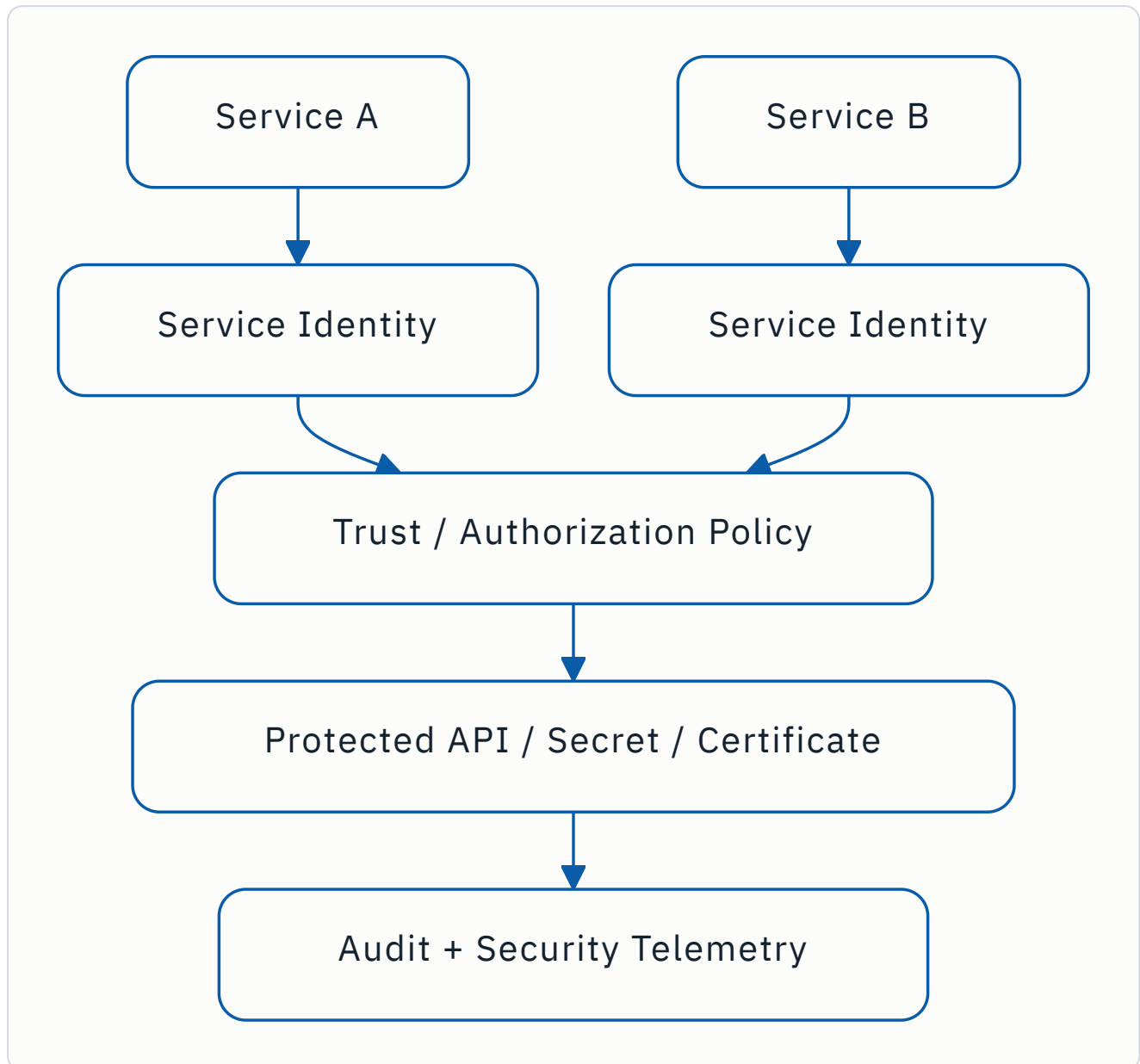
Slika 7. Pojednostavljen životni ciklus tajne ili pristupnog kredencijala.

6.5. Threat -> Control -> Evidence



Slika 8. Veza asset-a, pretnje, kontrole, testa i dokaza.

6.6. Service-to-service trust



Slika 9. Konceptualna granica poverenja između servisnih identiteta.

NAPOMENA.

Projekat je defanzivno orijentisan. Negativni i abuse scenariji izvide se nad sopstvenim testnim sistemom i simulatorima, bez napada na realne spoljne sisteme.

Pregled projektnih celina

Oznaka	Projektna celina	Nivo	Glavni preduslovi	Str.
R1-01	Organizacije, bezbednosni domeni i vlasništvo	R1	nema obaveznih	28
R1-02	Asset inventory i kritičnost resursa	R1	R1-01	28
R1-03	Identity registry i životni ciklus korisnika	R1	nema obaveznih	29
R1-04	Osnovna autentikacija	R1	R1-03	29
R1-05	Uloge i osnovni RBAC	R1	R1-03	30
R1-06	Object-level authorization i vlasništvo resursa	R1	R1-05, R1-02	31
R1-07	Klasifikacija podataka i pravila rukovanja	R1	R1-02	31
R1-08	Security policy katalog	R1	R1-01	32
R1-09	Audit log i bezbednosni događaji	R1	R1-03, R1-05	32
R1-10	Secure configuration baseline	R1	R1-02, R1-08	33
R1-11	Security notifications i odgovorni kontakti	R1	R1-01, R1-09	34
R1-12	Security simulatori i test identities	R1	nema obaveznih	34
R1-13	Bezbednosna observability osnova	R1	R1-09	35
R1-14	Security zone i trust-boundary registry	R1	R1-01, R1-02	36
R1-15	Data retention i secure disposal policy	R1	R1-07, R1-08	36
R1-16	Katalog bezbednosnih kontrola i vlasništvo	R1	R1-01, R1-08	37
R1-17	Cryptographic asset inventory	R1	R1-01, R1-02, R1-08	38
R1-18	External exposure i attack-surface registry	R1	R1-02, R1-14	38
R1-19	Security data-source i log-source registry	R1	R1-09, R1-13	39
R1-20	Data-flow i processing registry	R1	R1-07, R1-14, R1-02	40
R1-21	Consent i lawful-basis registry	R1	R1-07, R1-20	40
R1-22	Security training i awareness registry	R1	R1-01, R1-03	41
R1-23	Exception i policy waiver catalog	R1	R1-08, R1-16	42
R1-24	Machine/service account ownership registry	R1	R1-02, R1-03, R1-05	42
R1-25	Token, session i credential metadata registry	R1	R1-04, R1-09	43

Oznaka	Projektna celina	Nivo	Glavni preduslovi	Str.
R1-26	Endpoint i device inventory trust atributi	R1	R1-02, R1-14	44
R1-27	Evidence repository i chain-of-custody osnova	R1	R1-09, R1-16	44
R1-28	Security playbook katalog	R1	R1-11, R1-16	45
R1-29	Business impact i crown-jewel mapping	R1	R1-01, R1-02, R1-07	46
R1-30	Control ownership i responsibility matrix	R1	R1-01, R1-08, R1-16	47
R2-01	Multi-factor i step-up autentikacija	R2	R1-04, R1-12	49
R2-02	Sessions, tokens i revocation	R2	R1-04, R1-09	49
R2-03	Privileged Access i Just-in-Time pristup	R2	R1-05, R2-01	50
R2-04	Service identities i workload authentication	R2	R1-02, R1-08	51
R2-05	Secrets management i lifecycle	R2	R2-04, R1-09	51
R2-06	Certificates i key lifecycle	R2	R1-12, R2-04	52
R2-07	Security detection rules	R2	R1-09, R1-12	53
R2-08	Security alerts i triage	R2	R2-07, R1-11	53
R2-09	Security incident management	R2	R2-08, R1-02	54
R2-10	Investigation, evidence i timeline	R2	R2-09, R1-09	55
R2-11	Vulnerability registry i remediation	R2	R1-02, R1-12	55
R2-12	API i application security policies	R2	R1-08, R1-10	56
R2-13	Dependency i software supply-chain registry	R2	R1-02, R2-11	56
R2-14	Endpoint/device trust i posture	R2	R1-02, R1-12, R2-01	57
R2-15	Data protection i DLP događaji	R2	R1-07, R1-09, R1-14	58
R2-16	Backup protection i recovery assurance	R2	R1-02, R1-08, R2-05	58
R2-17	Security telemetry ingestion i normalizacija	R2	R1-19, R1-09, R1-12	59
R2-18	Kontrolisano deljenje i transfer osetljivih podataka	R2	R1-07, R1-20, R1-06, R1-09	60
R2-19	Kriptografska politika i orchestration rotacije	R2	R1-17, R2-05, R2-06, R1-08	60
R2-20	Security baseline drift i remediation	R2	R1-10, R1-16, R1-02, R1-12	61
R2-21	Consent lifecycle i preference enforcement	R2	R1-21, R1-07, R1-09	62

Oznaka	Projektna celina	Nivo	Glavni preduslovi	Str.
R2-22	Security training campaign workflow	R2	R1-22, R1-11, R1-09	62
R2-23	Policy exception workflow i compensating controls	R2	R1-23, R1-16, R1-09	63
R2-24	Service-account review i stale-credential cleanup	R2	R1-24, R2-04, R2-05	64
R2-25	Session anomaly i impossible-travel detection	R2	R2-02, R2-17, R1-13	64
R2-26	Device quarantine i access restriction workflow	R2	R1-26, R2-14, R2-08	65
R2-27	Evidence collection package i handoff workflow	R2	R1-27, R2-10, R2-09	66
R2-28	Incident playbook execution tracking	R2	R1-28, R2-09, R2-10	66
R2-29	Crown-jewel access monitoring	R2	R1-29, R1-06, R2-17	67
R2-30	Control attestation i owner follow-up	R2	R1-30, R3-07, R1-09	68
R3-01	Policy engine i atributska autorizacija	R3	R1-06, R1-07, R1-08	70
R3-02	Periodic access review i certification	R3	R1-05, R2-03, R2-04	70
R3-03	Risk register i procena bezbednosnog rizika	R3	R1-02, R2-11	71
R3-04	Threat modeling workflow	R3	R1-02, R3-03	71
R3-05	Security event correlation i analytics	R3	R1-09, R2-07	72
R3-06	Automatizacija containment i response akcija	R3	R2-02, R2-09, R2-05	73
R3-07	Compliance evidence i control mapping	R3	R1-08, R1-09	73
R3-08	Security exceptions i risk acceptance	R3	R1-08, R1-10, R3-03	74
R3-09	Post-incident review i security improvement tracking	R3	R2-09, R2-10	74
R3-10	Attack-path i exposure graph analiza	R3	R1-02, R1-14, R2-11, R3-04	75
R3-11	Third-party i supplier security assessment	R3	R1-02, R1-16, R3-03	76
R3-12	Continuous control effectiveness i security posture	R3	R1-16, R3-05, R3-07	76
R3-13	Segregation of duties i toxic-access analiza	R3	R1-05, R1-06, R2-03, R3-02	77
R3-14	Risk-based adaptive authentication	R3	R2-01, R2-02, R2-14, R1-08	78
R3-15	Detection engineering, simulacija i tuning pravila	R3	R2-07, R2-17, R1-12	78
R3-16	Data-access anomaly i exfiltration risk analitika	R3	R1-07, R2-15, R2-17, R3-05	79

Oznaka	Projektna celina	Nivo	Glavni preduslovi	Str.
R3-17	Software provenance i release trust verifikacija	R3	R2-13, R2-11, R1-16	80
R3-18	Privacy impact i data-processing assessment	R3	R1-07, R1-20, R3-03, R1-16	80
R3-19	Cryptographic posture i migration planning	R3	R1-17, R2-19, R3-10	81
R3-20	Security metrics, risk quantification i executive posture	R3	R3-03, R3-05, R3-07, R3-12	82
R3-21	Data-subject request i privacy rights workflow	R3	R1-21, R1-20, R2-18	82
R3-22	Human-risk analytics i targeted awareness planning	R3	R1-22, R2-22, R3-05	83
R3-23	Exception portfolio risk analytics	R3	R1-23, R2-23, R3-03	84
R3-24	Non-human identity posture analytics	R3	R1-24, R2-24, R3-12	84
R3-25	Identity threat hunting notebook	R3	R2-17, R2-25, R3-05	85
R3-26	Zero-trust readiness i maturity assessment	R3	R1-14, R2-14, R3-12	86
R3-27	Evidence quality scoring i audit readiness	R3	R1-27, R3-07, R2-27	86
R3-28	Security automation governance	R3	R1-28, R3-06, R3-08	87
R3-29	Crown-jewel risk scenario analysis	R3	R1-29, R3-03, R3-10	88
R3-30	Control assurance roadmap i gap planning	R3	R1-30, R3-12, R3-20	89

Projektne celine nivoa R1

Celine R1 formiraju osnovni model identiteta, asset-a, pristupa, klasifikacije, policy-ja i audit-a.

R1-01	Organizacije, bezbednosni domeni i vlasništvo	28	R1-02	Asset inventory i kritičnost resursa	28
R1-03	Identity registry i životni ciklus korisnika	29	R1-04	Osnovna autentikacija	29
R1-05	Uloge i osnovni RBAC	30	R1-06	Object-level authorization i vlasništvo resursa	31
R1-07	Klasifikacija podataka i pravila rukovanja	31	R1-08	Security policy katalog	32
R1-09	Audit log i bezbednosni događaji	32	R1-10	Secure configuration baseline	33
R1-11	Security notifications i odgovorni kontakti	34	R1-12	Security simulatori i test identities	34
R1-13	Bezbednosna observability osnova	35	R1-14	Security zone i trust-boundary registry	36
R1-15	Data retention i secure disposal policy	36	R1-16	Katalog bezbednosnih kontrola i vlasništvo	37
R1-17	Cryptographic asset inventory	38	R1-18	External exposure i attack-surface registry	38
R1-19	Security data-source i log-source registry	39	R1-20	Data-flow i processing registry	40
R1-21	Consent i lawful-basis registry	40	R1-22	Security training i awareness registry	41
R1-23	Exception i policy waiver catalog	42	R1-24	Machine/service account ownership registry	42
R1-25	Token, session i credential metadata registry	43	R1-26	Endpoint i device inventory trust atributi	44
R1-27	Evidence repository i chain-of-custody osnova	44	R1-28	Security playbook katalog	45
R1-29	Business impact i crown-jewel mapping	46	R1-30	Control ownership i responsibility matrix	47

R1-01**Organizacije, bezbednosni domeni i vlasništvo**

Model organizacionih celina, bezbednosnih domena i odgovornosti nad resursima.

Element	Specifikacija
Ključni pojmovi	Organization, SecurityDomain, Owner, Criticality, Scope
Preduslovi	Nema obaveznih funkcionalnih preduslova.
OBAVEZNI USE - CASE - OVI	■ kreiranje organizacije i bezbednosnog domena ■ dodela vlasnika ■ povezivanje resursa sa domenom ■ promena kritičnosti ■ deaktivacija domena
KLJUČNA BEZBEDNOSNA PRAVILA	■ svaki zaštićeni resurs mora imati vlasnika ili eksplicitno definisan sistemski scope ■ deaktiviran domen ne prima nove resurse ■ promena vlasništva mora biti auditovana
MOGUĆA PROŠIRENJA	■ hijerarhija domena ■ delegirani owner ■ shared ownership policy
DOKAZ ZAVRŠETKA.	Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

DOKAZ ZAVRŠETKA.**R1-02****Asset inventory i kritičnost resursa**

Centralna evidencija aplikacija, servisa, uređaja, podataka i drugih informacionih resursa.

Element	Specifikacija
Ključni pojmovi	Asset, AssetType, AssetOwner, Criticality, LifecycleStatus
Preduslovi	R1-01
OBAVEZNI USE - CASE - OVI	■ registracija asset-a ■ dodela vlasnika ■ klasifikacija kritičnosti ■ promena statusa ■ pretraga po domenu i vlasniku
KLJUČNA BEZBEDNOSNA PRAVILA	■ asset mora imati jedinstven identitet ■ dekomisioniran asset ostaje u istoriji ■ kritičnost mora biti eksplicitna i auditovana

R1-02

Asset inventory i kritičnost resursa

MOGUĆA PROŠIRENJA

- dependency link
- business service map
- asset import

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R1-03

Identity registry i životni ciklus korisnika

Upravljanje identitetima zaposlenih, saradnika i drugih ljudskih korisnika.

Element

Specifikacija

Ključni pojmovi

Identity, Person, Account, IdentityStatus, EmploymentContext

Preduslovi

Nema obaveznih funkcionalnih preduslova.

OBAVEZNI USE-CASE-OVI

- kreiranje identiteta
- aktiviranje/suspenzija
- povezivanje naloga
- promena statusa
- gašenje pristupa pri prestanku angažmana

KLJUČNA BEZBEDNOSNA PRAVILA

- jedna osoba ne sme nekontrolisano imati više nepovezanih privilegovanih identiteta
- suspendovan identitet ne može dobiti novu sesiju
- gašenje mora ukloniti aktivne privilegije prema politici

MOGUĆA PROŠIRENJA

- external identities
- identity merge
- temporary contractor lifecycle

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R1-04

Osnovna autentikacija

Pouzdana potvrda identiteta korisnika korišćenjem standardnih mehanizama i biblioteka.

Element

Specifikacija

Ključni pojmovi

Credential, AuthenticationAttempt, AuthenticationOutcome, PasswordPolicy, LockoutState

Preduslovi

R1-03

OBAVEZNI USE-CASE-OVI

- prijava korisnika
- odbijanje neispravnih podataka
- kontrolisani lockout/rate policy
- promena kredencijala
- oporavak pristupa kroz simulirani kanal

R1-04**Osnovna autentikacija****KLJUČNA
BEZBEDNOSNA
PRAVILA**

- lozinke se ne čuvaju u otvorenom obliku
- sopstveni kriptografski algoritmi nisu dozvoljeni
- odgovor ne sme nepotrebno otkrivati da li nalog postoji
- auth failure mora biti auditovan

MOGUĆA PROŠIRENJA

- passwordless adapter
- external IdP
- risk-based authentication signal

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R1-05**Uloge i osnovni RBAC**

Model uloga i dozvola nad funkcionalnim celinama sistema.

Element**Specifikacija****Ključni pojmovi**

Role, Permission, Assignment, Scope, EffectivePermission

Preduslovi

R1-03

**OBAVEZNI USE-
CASE-OVI**

- kreiranje uloge
- dodela dozvole
- dodela uloge korisniku
- ukidanje uloge
- izračunavanje efektivnih dozvola

**KLJUČNA
BEZBEDNOSNA
PRAVILA**

- dozvola se proverava serverski
- uloga ne sme implicitno davati pristup izvan scope-a
- privilegovana dodela se audit-uje

MOGUĆA PROŠIRENJA

- role hierarchy
- scoped role
- separation-of-duties rule

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R1-06**Object-level authorization i vlasništvo resursa**

Provera da li korisnik sme pristupiti konkretnom objektu, ne samo tipu endpoint-a.

Element**Specifikacija****Ključni pojmovi**

ProtectedResource, ResourceOwner, AccessDecision, Subject, Action

Preduslovi

R1-05, R1-02

OBAVEZNI USE-CASE-OVI

- provera vlasništva
- provera scope-a
- dozvola/odbijanje konkretne operacije
- promena owner-a
- negativni pristup tuđem resursu

KLJUČNA BEZBEDNOSNA PRAVILA

- poznavanje resource ID-a nije pravo pristupa
- UI filter ne zamenjuje serversku autorizaciju
- svaki deny treba dati kontrolisan ishod bez curenja podataka

MOGUĆA PROŠIRENJA

- shared resource access
- delegation
- resource group policy

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R1-07**Klasifikacija podataka i pravila rukovanja**

Klasifikovanje podataka prema osetljivosti i vezivanje bezbednosnih pravila za klasifikaciju.

Element**Specifikacija****Ključni pojmovi**

DataClassification, HandlingRule, RetentionClass, Sensitivity, DataOwner

Preduslovi

R1-02

OBAVEZNI USE-CASE-OVI

- definisanje klasifikacionog nivoa
- dodela klasifikacije resursu/dokumentu
- validacija dozvoljenog rukovanja
- promena klasifikacije
- pregled klasifikovanih resursa

KLJUČNA BEZBEDNOSNA PRAVILA

- klasifikacija mora imati vlasnika i značenje
- niži nivo zaštite ne sme automatski prepisati viši bez odobrenja
- retention i pristup moraju koristiti aktivnu klasifikaciju

R1-07

Klasifikacija podataka i pravila rukovanja

MOGUĆA PROŠIRENJA

- data labels
- handling matrix
- cross-domain sharing rule

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R1-08

Security policy katalog

Centralizovana evidencija bezbednosnih pravila i njihovog opsega primene.

Element

Specifikacija

Ključni pojmovi

SecurityPolicy, PolicyVersion, PolicyScope, EffectivePeriod, PolicyStatus

Preduslovi

R1-01

OBAVEZNI USE - CASE - OVI

- kreiranje politike
- verzionisanje
- aktiviranje nove verzije
- povezivanje sa domenom/asset-om
- arhiviranje stare verzije

KLJUČNA BEZBEDNOSNA PRAVILA

- objavljena politika se ne menja u mestu
- istorijski događaj mora moći da se poveže sa politikom koja je tada važila
- kontradiktorne politike zahtevaju definisano pravilo prioriteta

MOGUĆA PROŠIRENJA

- policy inheritance
- exception link
- policy review period

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R1-09

Audit log i bezbednosni događaji

Sledljiva evidencija značajnih bezbednosnih i administrativnih aktivnosti.

Element

Specifikacija

Ključni pojmovi

SecurityEvent, AuditEvent, Actor, Action, Target, Outcome, CorrelationId

Preduslovi

R1-03, R1-05

OBAVEZNI USE - CASE - OVI

- beleženje prijave i pristupa
- beleženje promene privilegije
- pretraga događaja
- korelacija aktivnosti
- izvoz ograničenog pregleda

R1-09**Audit log i bezbednosni događaji****KLJUČNA
BEZBEDNOSNA
PRAVILA**

- audit zapis se ne menja nakon upisa
- tajne i kredencijali se ne zapisuju
- bezbednosni događaj mora razlikovati uspešan i neuspešan ishod

MOGUĆA PROŠIRENJA

- tamper-evident hash
- retention
- event severity

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R1-10**Secure configuration baseline**

Definisanje i provera minimalnih bezbednosnih konfiguracionih zahteva za aplikacije i servise.

Element**Specifikacija****Ključni pojmovi**

SecurityBaseline, ConfigurationRule, TargetType, ComplianceStatus, ExceptionRef

Preduslovi

R1-02, R1-08

**OBAVEZNI USE-
CASE-OVI**

- kreiranje baseline-a
- povezivanje pravila sa asset tipom
- provera konfiguracije
- evidencija odstupanja
- odobravanje izuzetka kroz referencu

**KLJUČNA
BEZBEDNOSNA
PRAVILA**

- tajna nije konfiguraciona vrednost u plain text-u
- baseline mora imati verziju
- odstupanje ne sme biti skriveno promenom očekivane vrednosti bez politike

MOGUĆA PROŠIRENJA

- environment-specific baseline
- automated config scan
- baseline inheritance

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R1-11 Security notifications i odgovorni kontakti

Obaveštavanje odgovornih osoba o bezbednosno relevantnim promenama i događajima.

Element	Specifikacija
Ključni pojmovi	SecurityNotification, Recipient, Channel, NotificationType, DeliveryStatus
Preduslovi	R1-01, R1-09
OBAVEZNI USE-CASE-OVI	■ slanje upozorenja ■ obaveštenje vlasnika resursa ■ obaveštenje o promeni privilegije ■ praćenje statusa ■ ponovni pokušaj kroz simulator
KLJUČNA BEZBEDNOSNA PRAVILA	■ notification failure ne sme rušiti osnovnu bezbednosnu odluku ■ duplirani događaj ne treba nekontrolisano da generiše duplikate ■ obaveštenje ne sadrži tajne
MOGUĆA PROŠIRENJA	■ digest ■ escalation ■ quiet hours policy
DOKAZ ZAVRŠETKA.	Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R1-12 Security simulatori i test identities

Kontrolisano simuliranje spoljnih identiteta, MFA odgovora, bezbednosnih događaja i skenerskih nalaza.

Element	Specifikacija
Ključni pojmovi	SimulatorProfile, TestIdentity, SecuritySignal, Scenario, SimulationOutcome
Preduslovi	Nema obaveznih funkcionalnih preduslova.
OBAVEZNI USE-CASE-OVI	■ simulacija IdP odgovora ■ simulacija OTP/MFA toka ■ generisanje security event-a ■ generisanje vulnerability finding-a ■ ponovljiv scenario
KLJUČNA BEZBEDNOSNA PRAVILA	■ simulator ne implementira realni napad nad spoljnim sistemom ■ scenario mora biti ponovljiv ■ test identiteti se jasno odvajaju od realnih naloga

R1-12

Security simulatori i test identities

MOGUĆA PROŠIRENJA

- scenario library
- controlled failure
- time-based simulation

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R1-13

Bezbednosna observability osnova

Zajednička pravila za correlation, strukturisane logove i osnovne security metrike.

Element

Specifikacija

Ključni pojmovi

TraceContext, SecurityMetric, LogEvent, CorrelationId, SourceComponent

Preduslovi

R1-09

OBAVEZNI USE-CASE-OVI

- propagacija correlation id-a
- strukturisani log
- security counter/metrika
- pregled health signala
- povezivanje događaja kroz komponente

KLJUČNA BEZBEDNOSNA PRAVILA

- logovi ne sadrže lozinke, token vrednosti ili tajne
- security metric mora imati jasno značenje
- correlation ne sme biti jedini mehanizam autorizacije

MOGUĆA PROŠIRENJA

- distributed tracing
- SLO/SLA security metrics
- sampling policy

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R1-14

Security zone i trust-boundary registry

Eksplisitna evidencija trust zona, granica poverenja i dozvoljenih tokova između asset-a radi doslednog threat modelovanja i autorizacionih odluka.

Element	Specifikacija
Ključni pojmovi	TrustZone, TrustBoundary, DataFlow, EntryPoint, BoundaryOwner, TrustLevel
Preduslovi	R1-01, R1-02
OBAVEZNI USE-CASE-OVI	- kreiranje trust zone i dodela vlasnika - povezivanje asset-a sa jednom ili više relevantnih zona - evidencija data flow-a koji prelazi trust boundary - registracija entry/exit point-a i protokola na konceptualnom nivou - pregled svih crossing-a prema zoni i asset-u - deaktivacija ili promena zone uz impact pregled postojećih tokova
KLJUČNA BEZBEDNOSNA PRAVILA	- svaki trust-boundary crossing mora imati jasan izvor, odredište i vlasnika - spoljni/nepoznati izvor ne dobija implicitno poverenje - promena zone asset-a mora pokrenuti pregled relevantnih policy i threat pretpostavki - registry ne predstavlja firewall konfiguraciju i ne sme glumiti realnu mrežnu zaštitu
MOGUĆA PROŠIRENJA	- data-flow diagram iz registra - zone inheritance - integracija sa policy engine-om kao decision input
DOKAZ ZAVRŠETKA.	Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R1-15

Data retention i secure disposal policy

Model pravila koliko dugo se podaci čuvaju, kada se mogu bezbedno ukloniti i kako se evidentira legal/operational hold.

Element	Specifikacija
Ključni pojmovi	RetentionPolicy, DataClass, RetentionPeriod, LegalHold, DisposalRequest, DisposalEvidence
Preduslovi	R1-07, R1-08
OBAVEZNI USE-CASE-OVI	- definisanje retention pravila po klasifikaciji podataka - povezivanje dataset/asset tipa sa pravilom zadržavanja - izračunavanje planiranog datuma isteka - postavljanje i uklanjanje legal/operational hold-a - odobranje secure disposal zahteva - evidencija dokaza da je simulirano uklanjanje završeno prema politici
KLJUČNA BEZBEDNOSNA PRAVILA	- aktivan hold sprečava disposal bez eksplicitno dozvoljene procedure - promena retention pravila mora biti verzionisana i ne sme retroaktivno sakriti prethodni zahtev - disposal evidence ne sme sadržati samu osetljivu vrednost koja je uklonjena - istek perioda ne znači automatsko fizičko brisanje bez uspešnog workflow-a

R1-15**Data retention i secure disposal policy****MOGUĆA PROŠIRENJA**

- grace period i review pre disposal-a
- policy konflikt resolver
- retention dashboard po data klasi

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R1-16**Katalog bezbednosnih kontrola i vlasništvo**

Centralni katalog tehničkih i procesnih security kontrola, njihovih vlasnika, očekivanih dokaza i statusa implementacije.

Element**Specifikacija****Ključni pojmovi**

SecurityControl, ControlOwner, ControlType, ImplementationStatus, EvidenceRequirement, ReviewCycle

Preduslovi

R1-01, R1-08

OBAVEZNI USE-CASE-OVI

- registracija security kontrole i njenog cilja
- dodela control owner-a
- povezivanje kontrole sa policy zahtevom ili asset scope-om
- definisanje očekivanog tipa dokaza i perioda pregleda
- promena implementation statusa uz obrazloženje
- pregled kontrola bez vlasnika, dokaza ili aktuelnog review-a

KLJUČNA BEZBEDNOSNA PRAVILA

- kontrola bez vlasnika mora biti označena kao governance gap
- samo postojanje kontrolnog zapisa ne dokazuje da je kontrola efektivna
- promena cilja ili scope-a kontrole mora biti auditovana
- kontrola povučena iz upotrebe ostaje u istoriji radi sledljivosti prethodnih dokaza

MOGUĆA PROŠIRENJA

- control family/hierarchy
- mapiranje na više internih standarda
- automatski review reminder

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

Centralna evidencija kriptografskih sredstava i referenci na ključeve, sertifikate i tajne bez čuvanja njihovog osjetljivog sadržaja.

Element	Specifikacija
Ključni pojmovi	CryptoAsset, KeyReference, CertificateReference, SecretReference, Algorithm, Owner
Preduslovi	R1-01, R1-02, R1-08
OBAVEZNI USE-CASE-OVI	- registracija kriptografskog sredstva i njegove namene - dodjela vlasnika, sistema i bezbednosnog domena - evidencija algoritma, dužine i statusa bez izlaganja tajnog materijala - povezivanje sa aplikacijom, servisom ili uređajem - praćenje perioda važenja i planiranog datuma rotacije - označavanje sredstva kao compromised/revoked/retired - pregled kriptografskih sredstava po vlasniku, tipu i kritičnosti
KLJUČNA POSLOVNA PRAVILA	- inventar ne sme čuvati privatni ključ ili plaintext secret - svako aktivno sredstvo mora imati vlasnika i namenu - isteklo ili revoked sredstvo ne sme biti prikazano kao važeće - istorija statusa i rotacija mora ostati sledljiva - algoritam označen kao zabranjen politikom mora proizvesti nalaz
MOGUĆA PROŠIRENJA	- crypto policy katalog - import metadata iz PKI/vault simulatora - upozorenja na skori istek
DOKAZ ZAVRŠETKA:	Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Evidencija spolja izloženih servisa, endpoint-a, portova i domena radi razumevanja attack surface-a organizacije.

Element	Specifikacija
Ključni pojmovi	Exposure, InternetEndpoint, ServicePort, DomainName, ExposureOwner, ExposureStatus
Preduslovi	R1-02, R1-14
OBAVEZNI USE-CASE-OVI	- registracija spolja dostupnog endpoint-a ili servisa - povezivanje exposure-a sa asset-om, vlasnikom i security zonom - evidencija protokola, porta i namene - označavanje odobrenog, privremenog ili nepoznatog exposure-a - periodična potvrda da je exposure i dalje potreban - zatvaranje exposure zapisa nakon uklanjanja sa spoljne površine - pregled exposure-a po kritičnosti i vlasniku

R1-18

External exposure i attack-surface registry

KLJUČNA POSLOVNA PRAVILA

- svaki aktivni exposure mora imati vlasnika i poslovno obrazloženje
- nepoznat exposure mora biti označen za proveru, ne automatski proglašen ranjivošću
- zatvoren exposure ostaje u istoriji
- promena izloženosti kritičnog servisa mora biti auditovana
- endpoint detalji dostupni su samo u okviru dozvoljenog security scope-a

MOGUĆA PROŠIRENJA

- simulirani external discovery feed
- DNS/TLS metadata
- attack-surface trend po periodu

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

R1-19

Security data-source i log-source registry

Katalog izvora bezbednosnih događaja, logova i telemetry podataka sa informacijama o vlasniku, šemi, kvalitetu i očekivanoj dostupnosti.

Element

Specifikacija

Ključni pojmovi

SecurityDataSource, LogSource, EventSchema, SourceOwner, CollectionStatus, DataQuality

Preduslovi

R1-09, R1-13

OBAVEZNI USE-CASE-OVI

- registracija security/log izvora
- povezivanje izvora sa asset-om, servisom ili domenom
- definisanje očekivane šeme i kategorija događaja
- promena collection statusa i razloga prekida
- praćenje poslednjeg primljenog događaja i freshness-a
- evidencija data-quality problema
- pregled coverage-a ključnih asset-a security izvorima

KLJUČNA POSLOVNA PRAVILA

- izvor mora imati vlasnika i jasno definisanu svrhu prikupljanja
- gubitak izvora ne sme biti predstavljen kao odsustvo bezbednosnih događaja
- šema mora biti verzionisana kada se semantika promeni
- pristup osetljivim log metadata mora poštovati security scope
- data-quality problem mora ostati sledljiv do izvora i perioda

MOGUĆA PROŠIRENJA

- log onboarding checklist
- source criticality score
- simulator prekida log feed-a

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Model ključnih tokova podataka između sistema, trust zona i organizacija radi podrške threat modelingu, klasifikaciji i proceni zaštite podataka.

Element	Specifikacija
Ključni pojmovi	DataFlow, DataStore, ProcessingPurpose, SourceSystem, DestinationSystem, TrustBoundary
Preduslovi	R1-07, R1-14, R1-02
OBAVEZNI USE-CASE-OVI	- registracija toka podataka između izvora i odredišta - dodela klasifikacije podataka koji se prenose - evidencija poslovne svrhe i vlasnika toka - označavanje prelaska trust boundary-ja - povezivanje toka sa servisom, API-jem ili skladištem - promena ili deaktivacija toka uz istoriju - pregled tokova koji prenose osetljive klase podataka
KLJUČNA POSLOVNA PRAVILA	- aktivan tok osetljivih podataka mora imati vlasnika i dokumentovanu svrhu - prelazak trust granice mora imati definisanu zaštitnu kontrolu ili eksplicitan gap - deaktivacija toka ne briše istorijski model - klasifikacija odredišnog podatka ne sme biti tiho niža od politike bez odobrenog pravila - model ne sme sadržati stvarne tajne ili puni sadržaj korisničkih podataka
MOGUĆA PROŠIRENJA	- vizuelni DFD prikaz - data residency metadata - automatsko obogaćivanje threat modela
DOKAZ ZAVRŠETKA:	Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Evidencija osnova obrade, consent statusa i svrhe obrade kada se zaštićeni podaci koriste kroz više aplikacija ili poslovnih procesa.

Element	Specifikacija
Ključni pojmovi	ConsentRecord, LawfulBasis, ProcessingPurpose, DataSubjectCategory, ConsentStatus
Preduslovi	R1-07, R1-20
OBAVEZNI USE-CASE-OVI	- registracija lawful-basis osnova za tok ili obradu podataka - evidencija consent statusa po subjektu, svrsi i sistemu - promena ili povlačenje consent-a uz istoriju - pregled aktivnih obrada bez poznatog osnova - povezivanje consent/lawful-basis zapisa sa data-flow registry-jem - izvoz minimalnog audit dokaza za odluku o obradi

R1-21

Consent i lawful-basis registry

KLJUČNA
BEZBEDNOSNA
PRAVILA

- obrada koja zahteva consent ne sme biti označena kao dozvoljena bez aktivnog consent zapisa
- povlačenje consent-a ne briše istorijski audit dokaz
- lawful basis, purpose i data category moraju biti eksplicitni
- scope consent-a ne sme biti proširen bez nove odluke ili pravila
- evidence ne sme sadržati nepotrebne lične podatke

MOGUĆA PROŠIRENJA

- preference centar
- data-subject notice template
- policy mapping po jurisdikciji bez pravnog sertifikovanja

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

R1-22

Security training i awareness registry

Evidencija bezbednosnih treninga, ciljnih grupa i statusa završetka radi podrške awareness kampanjama i merenju obaveza.

Element

Specifikacija

Ključni pojmovi

TrainingModule, AudienceGroup, TrainingAssignment, CompletionStatus, AwarenessTopic

Preduslovi

R1-01, R1-03

OBAVEZNI USE-
CASE-OVI

- kreiranje modula bezbednosne obuke
- dodela modula ciljnoj grupi ili ulozi
- evidencija završetka i rezultata kviza/simulacije
- pregled korisnika sa isteklom ili nezavršenom obukom
- verzionisanje sadržaja obuke
- deaktivacija modula uz očuvanje istorije

KLJUČNA
BEZBEDNOSNA
PRAVILA

- obavezna obuka mora imati ciljnu grupu, rok i owner-a
- promena sadržaja ne sme retroaktivno izmeniti prethodno završene zapise
- status završetka mora biti vezan za korisnika i verziju modula
- obuka ne sme sadržati stvarne tajne ili realne phishing linkove

MOGUĆA PROŠIRENJA

- awareness score
- reminder politika
- simulirani phishing kao kontrolisana edukativna vežba bez stvarne infrastrukture

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Katalog izuzetaka od bezbednosnih politika i waiver zapisa koji omogućavaju kontrolisano praćenje razloga, scope-a i datuma isteka.

Element	Specifikacija
Ključni pojmovi	PolicyException, Waiver, CompensatingControl, ExpiryDate, ExceptionOwner
Preduslovi	R1-08, R1-16
OBAVEZNI USE-CASE-OVI	- kreiranje zahteva za izuzetak od politike - dodela owner-a i risk obrazloženja - povezivanje izuzetka sa kontrolom i asset-om - definisanje compensating control zapisa - pregled aktivnih i isteklih izuzetaka - deaktivacija ili zatvaranje izuzetka uz dokaz
KLJUČNA BEZBEDNOSNA PRAVILA	- izuzetak mora imati razlog, scope, owner-a i datum isteka - istekao izuzetak ne sme validirati neusaglašeno stanje - compensating control mora biti proverljiv ili označen kao planiran - izuzetak ne sme služiti kao trajna zamena za politiku bez odluke nastavnog tima
MOGUĆA PROŠIRENJA	- approval workflow - bulk review kampanja - exception heatmap
DOKAZ ZAVRŠETKA:	Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Evidencija non-human identiteta, njihovih owner-a, svrhe i minimalnog scope-a radi kontrole servisnih naloga i automatizovanih integracija.

Element	Specifikacija
Ključni pojmovi	ServiceAccount, MachineIdentity, Ownership, CredentialBinding, AllowedScope
Preduslovi	R1-02, R1-03, R1-05
OBAVEZNI USE-CASE-OVI	- registracija service account-a ili machine identity-ja - dodela tehničkog i poslovnog owner-a - evidencija svrhe i dozvoljenog scope-a - povezivanje identiteta sa credential zapisom bez čuvanja tajne - pregled naloga bez owner-a ili sa preširokim scope-om - deaktivacija identiteta uz očuvanje istorije

R1-24

Machine/service account ownership registry

KLJUČNA
BEZBEDNOSNA
PRAVILA

- service account ne sme biti aktivan bez owner-a i svrhe
- dozvoljeni scope mora biti eksplicitno naveden
- tajni materijal se ne čuva u registry-ju
- promena owner-a ili scope-a mora ostaviti audit trag
- deaktiviran identitet ne sme biti ponuđen kao aktivan consumer-u

MOGUĆA PROŠIRENJA

- naming standard
- owner attestation
- stale account kandidati

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

R1-25

Token, session i credential metadata registry

Evidencija metadata o tokenima, sesijama i credential tipovima bez čuvanja samih tajni, radi podrške revocation-u, audit-u i policy odlukama.

Element

Specifikacija

Ključni pojmovi

TokenFamily, SessionMetadata, CredentialType, Issuer, AssuranceLevel, RevocationState

Preduslovi

R1-04, R1-09

OBAVEZNI USE-
CASE-OVI

- registracija token/session family tipa
- evidencija issuer-a, assurance nivoa i roka važenja
- povezivanje session metadata sa audit događajem
- označavanje revoked/expired statusa
- pregled token tipova sa predugim važenjem
- deaktivacija credential tipa

KLJUČNA
BEZBEDNOSNA
PRAVILA

- vrednost tokena ili lozinke se nikada ne skladišti
- metadata mora biti dovoljan za revocation i audit bez otkrivanja tajne
- revoked status mora biti jednoznačan
- issuer i assurance level moraju biti poznati za bezbednosno značajne odluke

MOGUĆA PROŠIRENJA

- token family visualization
- session inventory dashboard
- risk tags po tipu credential-a

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

R1-26**Endpoint i device inventory trust atributi**

Osnovni registry uređaja i endpoint trust atributa koji omogućava kasnije posture procene i access odluke.

Element	Specifikacija
Ključni pojmovi	Device, Endpoint, DeviceOwner, PostureAttribute, EnrollmentStatus, TrustLevel
Preduslovi	R1-02, R1-14

OBAVEZNI USE-CASE-OVI	- registracija uređaja ili endpoint-a - dodela owner-a i security domena - evidencija enrollment i posture atributa - promena trust level-a uz razlog - pregled nepoznatih ili unmanaged uređaja - deaktivacija izgubljenog ili povučenog uređaja
-----------------------	--

KLJUČNA BEZBEDNOSNA PRAVILA	- uređaj bez owner-a ne sme imati visok trust level - posture atributi moraju imati izvor i vreme poslednje provere - trust level je metadata za odluku, ne garancija bezbednosti - deaktiviran uređaj ne sme biti ponuđen kao validan endpoint
-----------------------------	--

MOGUĆA PROŠIRENJA	- MDM simulator - device risk label - privremeno trusted stanje sa rokom
-------------------	--

DOKAZ ZAVRŠETKA:	Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.
-------------------------	--

R1-27**Evidence repository i chain-of-custody osnova**

Osnovni repozitorijum dokaza za security događaje, incidente i kontrole, sa metapodacima o poreklu, integritetu i pristupu.

Element	Specifikacija
Ključni pojmovi	EvidenceItem, ChainOfCustody, EvidenceSource, HashRecord, AccessLog
Preduslovi	R1-09, R1-16

OBAVEZNI USE-CASE-OVI	- kreiranje evidence item-a bez čuvanja nepotrebnog sadržaja - povezivanje dokaza sa incidentom, kontrolom ili nalazom - evidencija izvora i vremena prikupljanja - evidencija hash/integrity metadata - kontrolisan pristup dokazu - pregled chain-of-custody zapisa
-----------------------	--

KLJUČNA BEZBEDNOSNA PRAVILA	- evidence item mora imati izvor, owner-a i klasifikaciju - pristup dokazu mora biti auditovan - promena metadata ne sme izbrisati prethodni chain-of-custody zapis - dokaz ne sme sadržati lozinke, tokene ili nepotrebne lične podatke
-----------------------------	---

R1-27**Evidence repository i chain-of-custody osnova**

MOGUĆA PROŠIRENJA

- export evidence package
- integrity verification simulator
- retention policy po tipu dokaza

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

R1-28**Security playbook katalog**

Katalog standardizovanih playbook koraka za incidente i operativne bezbednosne procese, bez automatskog izvršavanja stvarnih akcija.

Element**Specifikacija****Ključni pojmovi**

Playbook, PlaybookStep, TriggerCondition, RequiredRole, SafetyCheck

Preduslovi

R1-11, R1-16

OBAVEZNI USE -
CASE-OVI

- kreiranje playbook-a za security scenario
- definisanje koraka i preduslova
- dodela odgovorne uloge po koraku
- verzionisanje playbook-a
- deaktivacija zastarelog playbook-a
- pregled playbook-a relevantnih za tip incidenta

KLJUČNA
BEZBEDNOSNA
PRAVILA

- playbook korak mora imati jasnu namenu i očekivani dokaz izvršenja
- opasna akcija mora imati safety check ili oznaku da je ručna
- promena playbook-a ne menja istoriju izvršenih slučajeva
- playbook ne sme sadržati stvarne tajne ili instrukcije za napad na realne sisteme

MOGUĆA PROŠIRENJA

- playbook template-i
- severity-based varijante
- mapping na MITRE tehniku kao edukativni metadata

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Klasifikacija najkritičnijih asset-a, procesa i podataka radi prioritizacije zaštite, rizika i monitoring fokusa.

Element	Specifikacija
Ključni pojmovi	CrownJewelAsset, BusinessImpact, CriticalProcess, ImpactCategory, RecoveryPriority
Preduslovi	R1-01, R1-02, R1-07
OBAVEZNI USE-CASE-OVI	■ označavanje crown-jewel asset-a ili procesa ■ dodela business impact kategorije ■ povezivanje asset-a sa vlasnikom i klasifikacijom podataka ■ pregled kritičnih resursa bez kontrole ili owner-a ■ promena impact procene uz obrazloženje ■ deaktivacija oznake kada asset više nije kritičan
KLJUČNA BEZBEDNOSNA PRAVILA	■ crown-jewel oznaka mora imati owner-a i razlog ■ visok impact ne sme biti automatski izjednačen sa visokim rizikom bez threat/kontrolnog konteksta ■ promena impact-a mora ostaviti audit trag ■ kritičan resurs bez owner-a predstavlja gap
MOGUĆA PROŠIRENJA	■ impact heatmap ■ business process map ■ priority tag za incident triage
DOKAZ ZAVRŠETKA:	Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Matrica odgovornosti nad bezbednosnim kontrolama, owner-ima, evidencijom i proverama efektivnosti.

Element	Specifikacija
Ključni pojmovi	ControlOwner, ResponsibilityMatrix, RACI, EvidenceRequirement, ReviewCadence
Preduslovi	R1-01, R1-08, R1-16
OBAVEZNI USE-CASE-OVI	- dodela owner-a bezbednosnoj kontroli - definisanje RACI uloga - povezivanje kontrole sa očekivanim evidence-om - definisanje cadence-a provere - pregled kontrola bez owner-a ili evidence zahteva - promena odgovornosti uz istoriju
KLJUČNA BEZBEDNOSNA PRAVILA	- aktivna kontrola mora imati owner-a - kontrola koja zahteva evidence mora navesti tip dokaza - RACI uloge ne smeju biti kontradiktorne - promena owner-a ne sme obrisati prethodnu odgovornost
MOGUĆA PROŠIRENJA	- control calendar - ownership dashboard - bulk reassignment
DOKAZ ZAVRŠETKA:	Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Projektne celine nivoa R2

Celine R2 uvode aktivne mehanizme zaštite, operativne bezbednosne procese i reakciju na security signal.

R2-01	Multi-factor i step-up autentikacija	49	R2-02	Sessions, tokens i revocation	49
R2-03	Privileged Access i Just-in-Time pristup	50	R2-04	Service identities i workload authentication	51
R2-05	Secrets management i lifecycle	51	R2-06	Certificates i key lifecycle	52
R2-07	Security detection rules	53	R2-08	Security alerts i triage	53
R2-09	Security incident management	54	R2-10	Investigation, evidence i timeline	55
R2-11	Vulnerability registry i remediation	55	R2-12	API i application security policies	56
R2-13	Dependency i software supply-chain registry	56	R2-14	Endpoint/device trust i posture	57
R2-15	Data protection i DLP događaji	58	R2-16	Backup protection i recovery assurance	58
R2-17	Security telemetry ingestion i normalizacija	59	R2-18	Kontrolisano deljenje i transfer osetljivih podataka	60
R2-19	Kriptografska politika i orchestration rotacije	60	R2-20	Security baseline drift i remediation	61
R2-21	Consent lifecycle i preference enforcement	62	R2-22	Security training campaign workflow	62
R2-23	Policy exception workflow i compensating controls	63	R2-24	Service-account review i stale-credential cleanup	64
R2-25	Session anomaly i impossible-travel detection	64	R2-26	Device quarantine i access restriction workflow	65
R2-27	Evidence collection package i handoff workflow	66	R2-28	Incident playbook execution tracking	66
R2-29	Crown-jewel access monitoring	67	R2-30	Control attestation i owner follow-up	68

R2-01**Multi-factor i step-up autentikacija**

Dodatna potvrda identiteta za rizične ili privilegovane operacije.

Element**Specifikacija****Ključni pojmovi**

MfaChallenge, Factor, StepUpContext, ChallengeStatus, RiskReason

Preduslovi

R1-04, R1-12

OBAVEZNI USE-CASE-OVI

- pokretanje MFA challenge-a
- potvrda faktora kroz simulator
- istek challenge-a
- step-up za privilegovanu operaciju
- odbijanje ponovljenog/zastarelog challenge-a

KLJUČNA BEZBEDNOSNA PRAVILA

- MFA token/challenge ima kratak vek
- uspešna osnovna prijava ne znači automatski dovoljan assurance za svaku operaciju
- replay challenge-a mora biti odbijen

MOGUĆA PROŠIRENJA

- multiple factors
- remembered device policy
- risk-triggered step-up

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R2-02**Sessions, tokens i revocation**

Upravljanje aktivnim sesijama i tokenima bez oslanjanja na beskonačno važenje pristupa.

Element**Specifikacija****Ključni pojmovi**

Session, AccessTokenRef, RefreshTokenRef, Revocation, SessionState

Preduslovi

R1-04, R1-09

OBAVEZNI USE-CASE-OVI

- kreiranje sesije
- obnova pristupa
- ukidanje sesije
- ukidanje svih sesija korisnika
- pregled aktivnih sesija

KLJUČNA BEZBEDNOSNA PRAVILA

- token životni vek mora biti konačan
- revoked session ne sme nastaviti da dobija pristup
- token vrednosti se ne zapisuju u log

R2-02**Sessions, tokens i revocation****MOGUĆA PROŠIRENJA**

- device-bound session
- session risk score
- concurrent session policy

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R2-03**Privileged Access i Just-in-Time pristup**

Privremeno dodeljivanje privilegovanih prava uz odobrenje, step-up i automatski istek.

Element**Specifikacija****Ključni pojmovi**

PrivilegedAccessRequest, Approval, PrivilegeGrant, ExpiresAt, Revocation

Preduslovi

R1-05, R2-01

OBAVEZNI USE-CASE-OVI

- podnošenje zahteva
- odobravanje/odbijanje
- step-up potvrda
- aktiviranje privilegije
- automatski istek
- hitno ukidanje

KLJUČNA BEZBEDNOSNA PRAVILA

- privilegija mora imati razlog i rok
- odobrenje i izvršenje mogu zahtevati separation of duties
- istekla privilegija se ne oslanja na ručno čišćenje

MOGUĆA PROŠIRENJA

- break-glass access
- dual approval
- privileged session review

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R2-04**Service identities i workload authentication**

Identitet i autentikacija aplikacija/servisa koji međusobno komuniciraju.

Element	Specifikacija
Ključni pojmovi	ServiceIdentity, ClientCredentialRef, ServiceScope, TrustStatus, CredentialVersion

Preduslovi	R1-02, R1-08
------------	--------------

OBAVEZNI USE-CASE-OVI	■ registracija servisnog identiteta ■ dodela scope-a ■ autentikacija servisa ■ ukidanje identiteta ■ rotacija pristupnog kredencijala
-----------------------	---

KLJUČNA BEZBEDNOSNA PRAVILA	■ ljudski nalog se ne koristi kao servisni identitet ■ servis dobija minimalno potreban scope ■ shared credential između više nepovezanih servisa nije prihvatljiv
-----------------------------	--

MOGUĆA PROŠIRENJA	■ workload identity ■ short-lived service token ■ service-to-service policy
-------------------	---

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R2-05**Secrets management i lifecycle**

Centralno upravljanje tajnama i pristupnim kredencijalima uz kontrolisan pristup i rotaciju.

Element	Specifikacija
Ključni pojmovi	Secret, SecretVersion, SecretScope, Lease, RotationPolicy

Preduslovi	R2-04, R1-09
------------	--------------

OBAVEZNI USE-CASE-OVI	■ kreiranje tajne ■ čuvanje verzije ■ kontrolisan pristup ■ rotacija ■ revocation ■ audit korišćenja
-----------------------	---

KLJUČNA BEZBEDNOSNA PRAVILA	■ tajna se ne čuva u source code-u ■ vrednost tajne se ne prikazuje korisniku koji nema potreban scope ■ rotacija ne sme zahtevati ručno menjanje tajne na više mesta bez evidencije
-----------------------------	--

R2-05**Secrets management i lifecycle****MOGUĆA PROŠIRENJA**

- secret lease
- dynamic secret simulator
- automatic rotation

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R2-06**Certificates i key lifecycle**

Evidencija i kontrolisani životni ciklus sertifikata i kriptografskih ključeva koristeći standardne biblioteke i simuliranu CA.

Element**Specifikacija****Ključni pojmovi**

Certificate, KeyRef, Issuer, ValidFrom, ValidTo, RevocationStatus

Preduslovi

R1-12, R2-04

OBAVEZNI USE-CASE-OVI

- zahtev za sertifikatom
- izdavanje kroz simulator CA
- provera važenja
- obnova
- revocation
- upozorenje pred istek

KLJUČNA BEZBEDNOSNA PRAVILA

- privatni ključ se ne loguje niti prikazuje nepotrebno
- istekao/revoked sertifikat se ne smatra važećim
- student ne implementira sopstvenu kriptografiju

MOGUĆA PROŠIRENJA

- certificate inventory
- key usage policy
- automatic renewal

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R2-07

Security detection rules

Pravila koja nad bezbednosnim događajima prepoznaju sumnjive obrasce ili kršenje politike.

Element	Specifikacija
Ključni pojmovi	DetectionRule, RuleCondition, Window, Severity, DetectionOutcome
Preduslovi	R1-09, R1-12
OBAVEZNI USE-CASE-OVI	■ kreiranje pravila ■ obrada security event-a ■ detekcija praga/obrasca ■ suppression/deduplikacija ■ promena severity-a
KLJUČNA BEZBEDNOSNA PRAVILA	■ pravilo mora imati objašnjiv uslov ■ jedan događaj ne mora automatski značiti incident ■ false positive/negative posledice moraju biti dokumentovane
MOGUĆA PROŠIRENJA	■ windowed correlation ■ multiple event types ■ rule testing harness
DOKAZ ZAVRŠETKA.	Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R2-08

Security alerts i triage

Vođenje alert-a od detekcije do odluke da li zahteva incident ili se zatvara kao nerelevantan signal.

Element	Specifikacija
Ključni pojmovi	SecurityAlert, AlertStatus, TriageDecision, Severity, Owner
Preduslovi	R2-07, R1-11
OBAVEZNI USE-CASE-OVI	■ kreiranje alert-a ■ dodela odgovornog analitičara ■ triage ■ eskalacija u incident ■ zatvaranje uz razlog
KLJUČNA BEZBEDNOSNA PRAVILA	■ zatvaranje zahteva razlog ■ critical alert ima eksplicitnu eskalaciju ■ duplirani alert-i ne smeju nekontrolisano stvarati incidente

R2-08

Security alerts i triage

MOGUĆA PROŠIRENJA

- alert grouping
- SLA za triage
- suppression policy

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R2-09

Security incident management

Vođenje životnog ciklusa bezbednosnog incidenta od prijave do zatvaranja.

Element

Specifikacija

Ključni pojmovi

SecurityIncident, IncidentStatus, Severity, IncidentOwner, ContainmentStatus

Preduslovi

R2-08, R1-02

OBAVEZNI USE-CASE-OVI

- otvaranje incidenta
- procena severity/impact-a
- dodela owner-a
- containment status
- recovery status
- zatvaranje

KLJUČNA BEZBEDNOSNA PRAVILA

- incident mora imati jasan scope i pogođene asset-e gde je poznato
- zatvaranje zahteva rezime rešenja
- kritičan incident ne može nestati brisanjem događaja

MOGUĆA PROŠIRENJA

- major incident mode
- incident SLA
- incident communication plan

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R2-10**Investigation, evidence i timeline**

Strukturisano prikupljanje artefakata i vremenske linije tokom istrage incidenta.

Element	Specifikacija
Ključni pojmovi	Evidence, EvidenceType, TimelineEntry, Source, IntegrityMetadata
Preduslovi	R2-09, R1-09
OBAVEZNI USE-CASE-OVI	■ dodavanje dokaza ■ povezivanje sa incidentom ■ timeline događaj ■ kontrolisan pristup dokazu ■ izvoz istrage
KLJUČNA BEZBEDNOSNA PRAVILA	■ evidence se ne menja bez nove verzije/zapisa ■ pristup dokazima je strože kontrolisan od običnog incident pregleda ■ integrity metadata ne sme biti predstavljena kao forenzički dokaz ako mehanizam to ne garantuje
MOGUĆA PROŠIRENJA	■ evidence chain metadata ■ attachment hashing ■ timeline correlation
DOKAZ ZAVRŠETKA.	Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R2-11**Vulnerability registry i remediation**

Evidencija poznatih slabosti, nalaza i plana otklanjanja bez izvođenja napada nad realnim sistemima.

Element	Specifikacija
Ključni pojmovi	VulnerabilityFinding, Severity, AffectedAsset, Remediation, FindingStatus
Preduslovi	R1-02, R1-12
OBAVEZNI USE-CASE-OVI	■ uvoz simuliranog nalaza ■ povezivanje sa asset-om ■ procena prioriteta ■ dodela remediation owner-a ■ zatvaranje nalaza uz dokaz
KLJUČNA BEZBEDNOSNA PRAVILA	■ nalaz bez pogođenog asset-a mora ostati jasno označen kao nepotpun ■ severity nije isto što i poslovni risk ■ zatvaranje mora imati verifikacioni dokaz

R2-11**Vulnerability registry i remediation****MOGUĆA PROŠIRENJA**

- CVSS-like metadata
- exception/acceptance
- retest workflow

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R2-12**API i application security policies**

Centralizovana pravila za osnovnu zaštitu aplikacionih i API granica.

Element**Specifikacija****Ključni pojmovi**

ApiSecurityPolicy, EndpointClass, RatePolicy, InputPolicy, SecurityHeaderPolicy

Preduslovi

R1-08, R1-10

OBAVEZNI USE-CASE-OVI

- povezivanje endpoint-a sa policy klasom
- provera auth/authz zahteva
- rate policy
- input size/shape ograničenje
- security configuration check

KLJUČNA BEZBEDNOSNA PRAVILA

- validacija input-a ne zamenjuje poslovnu validaciju
- rate limit mora imati jasan scope
- security header ili API policy mora biti testiran, ne samo dokumentovan

MOGUĆA PROŠIRENJA

- CORS policy registry
- API client policy
- gateway integration

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R2-13**Dependency i software supply-chain registry**

Evidencija softverskih zavisnosti, paketa i poznatih rizika u lancu isporuke.

Element**Specifikacija****Ključni pojmovi**

SoftwareComponent, Dependency, Version, Source, KnownRisk

Preduslovi

R1-02, R2-11

OBAVEZNI USE-CASE-OVI

- registracija komponente
- uvoz dependency liste
- povezivanje nalaza sa verzijom
- upgrade/remediation plan
- evidencija odobrenog izuzetka

R2-13

Dependency i software supply-chain registry

KLJUČNA
BEZBEDNOSNA
PRAVILA

- paket mora imati identitet i verziju
- nepoznat izvor zavisnosti mora biti vidljiv risk signal
- zatvaranje rizika zahteva novu/verifikovanu verziju ili prihvaćen izuzetak

MOGUĆA PROŠIRENJA

- SBOM import
- license/security metadata
- dependency freshness policy

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R2-14

Endpoint/device trust i posture

Procena poverenja u uređaj sa kog korisnik pristupa sistemu korišćenjem simuliranih posture signala kao dodatnog input-a bezbednosne odluke.

Element

Specifikacija

Ključni pojmovi

DeviceIdentity, DevicePosture, TrustLevel, AttestationResult, PostureSignal, AccessSignal

Preduslovi

R1-02, R1-12, R2-01

OBAVEZNI USE-
CASE-OVI

- registracija upravljanog test uređaja
- prijem simuliranih posture signala poput encryption/patch/agent statusa
- izračunavanje trenutnog trust nivoa prema verzionisanoj politici
- označavanje izgubljenog ili kompromitovanog uređaja
- izlaganje posture signala authentication/policy komponenti
- negativni scenario pristupa sa non-compliant uređaja

KLJUČNA
BEZBEDNOSNA
PRAVILA

- posture signal mora imati vreme važenja i ne sme se trajno smatrati svežim
- device trust ne zamenjuje identity authentication
- nepoznat uređaj mora imati eksplicitan default tretman
- osetljivi detalji uređaja ne smeju se nepotrebno izlagati drugim tenant-ima ili korisnicima

MOGUĆA PROŠIRENJA

- risk-based step-up MFA signal
- simulator MDM/EDR izvora
- trusted-device enrollment approval

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R2-15**Data protection i DLP događaji**

Detekcija i kontrolisan odgovor na pokušaje prenosa klasifikovanih podataka ka nedozvoljenom ili visokorizičnom odredištu u sopstvenom testnom sistemu.

Element	Specifikacija
Ključni pojmovi	DlpPolicy, DataMovement, DestinationClass, DlpDecision, DlpEvent, ExceptionRef
Preduslovi	R1-07, R1-09, R1-14
OBAVEZNI USE-CASE-OVI	■ definisanje DLP pravila prema data klasi i destination tipu ■ evaluacija simuliranog upload/export/email scenarija ■ dozvola, upozorenje ili blokada prema politici ■ generisanje security event-a za relevantan pokušaj ■ povezivanje odobrenog izuzetka kada postoji ■ pregled ponovljenih ili visokorizičnih DLP događaja bez otkrivanja punog sadržaja
KLJUČNA BEZBEDNOSNA PRAVILA	■ DLP log ne sme skladištiti punu osetljivu vrednost kada je dovoljan fingerprint/metapodatak ■ odluka mora uzeti u obzir klasifikaciju i trust/destination kontekst ■ exception mora imati scope i rok važenja ■ projekat ne sme slati realne osetljive podatke niti testirati spoljne servise bez dozvole
MOGUĆA PROŠIRENJA	■ content fingerprint simulator ■ user justification workflow ■ correlation sa incident modulom
DOKAZ ZAVRŠETKA.	Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R2-16**Backup protection i recovery assurance**

Bezbednosna evidencija zaštite backup kopija, pristupa, enkripcionog statusa i periodičnih restore provera bez implementacije storage proizvoda od nule.

Element	Specifikacija
Ključni pojmovi	ProtectedBackup, BackupPolicy, EncryptionStatus, AccessPolicy, RestoreTest, RecoveryEvidence
Preduslovi	R1-02, R1-08, R2-05
OBAVEZNI USE-CASE-OVI	■ registracija backup seta i pripadajućeg zaštićenog asset-a ■ evidencija encryption i access-policy statusa ■ kontrola ko sme pokrenuti restore test ■ periodična provera čitljivosti/restore sposobnosti kroz simulator ■ evidencija neuspeha, zastarelosti ili nedostajućeg backup-a ■ generisanje recovery evidence zapisa za review

R2-16

Backup protection i recovery assurance

KLJUČNA
BEZBEDNOSNA
PRAVILA

- backup koji nije potvrđeno zaštićen ne sme biti označen kao compliant samo zato što postoji
- restore test se izvodi u izolovanom testnom scope-u
- secret/key vrednosti se ne čuvaju u backup registru
- dokaz mora razlikovati poslednji uspešan backup od poslednjeg uspešnog restore testa

MOGUĆA PROŠIRENJA

- immutable/WORM status simulator
- dual-control restore approval
- ransomware recovery tabletop scenario

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R2-17

Security telemetry ingestion i normalizacija

Prijem defanzivnih security događaja iz više simuliranih izvora, validacija šeme i normalizacija u zajednički bezbednosni model.

Element

Specifikacija

Ključni pojmovi

SecurityEvent, IngestionSource, NormalizedEvent, ParserVersion, QualityFlag, EventId

Preduslovi

R1-19, R1-09, R1-12

OBAVEZNI USE-
CASE-OVI

- prijem događaja iz simuliranog log/security izvora
- validacija minimalnih obaveznih polja
- normalizacija vremena, identiteta, asset reference i event kategorije
- označavanje nepoznatog ili delimično parsiranog događaja
- deduplikacija identičnog event-a prema stabilnom identitetu
- rutiranje validnog događaja ka detection sloju
- praćenje parser error rate-a i source freshness-a

KLJUČNA POSLOVNA
PRAVILA

- nevalidan događaj se ne sme tiho pretvoriti u validan bez quality oznake
- duplikat ne sme nekontrolisano proizvesti više istih downstream posledica
- parser verzija mora ostati poznata za istorijski događaj
- ingestion ne sme menjati izvorni security audit zapis
- očekivani prekid izvora mora biti različit od normalnog odsustva događaja

MOGUĆA PROŠIRENJA

- batch ingest
- dead-letter security events
- schema compatibility testovi

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Workflow odobravanja i evidentiranja transfera klasifikovanih podataka između korisnika, sistema ili trust zona.

Element	Specifikacija
Ključni pojmovi	TransferRequest, DataPackage, Destination, Approval, ProtectionRequirement, TransferOutcome
Preduslovi	R1-07, R1-20, R1-06, R1-09
OBAVEZNI USE - CASE - OVI	■ kreiranje zahteva za deljenje ili transfer klasifikovanih podataka ■ provera destination trust zone i dozvoljene klasifikacije ■ određivanje potrebnih zaštitnih mera prema policy-ju ■ odobravanje/odbijanje zahteva od odgovarajuće uloge ■ evidencija simuliranog transfera bez čuvanja realnog osetljivog sadržaja ■ opoziv ili istek prethodno odobrenog transfera ■ audit pregled transfera po vlasniku i periodu
KLJUČNA POSLOVNA PRAVILA	■ korisnik ne može sam sebi odobriti transfer kada politika zahteva drugu ulogu ■ transfer u manje pouzdanu zonu mora biti blokiran ili imati eksplicitan odobren izuzetak ■ odobrenje mora važiti za konkretan scope i period ■ audit ne sme čuvati tajni sadržaj transferisanih podataka ■ isteklo odobrenje ne sme važiti za novi transfer
MOGUĆA PROŠIRENJA	■ watermark/tag metadata ■ one-time sharing link simulator ■ DLP događaj nakon pokušaja nedozvoljenog transfera
DOKAZ ZAVRŠETKA:	Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Planiranje i kontrolisano sprovođenje rotacije ključeva, sertifikata i tajni na osnovu kriptografskog inventara i policy-ja.

Element	Specifikacija
Ključni pojmovi	CryptoPolicy, RotationPlan, RotationStep, CryptoFinding, CompatibilityCheck, RollbackPlan
Preduslovi	R1-17, R2-05, R2-06, R1-08
OBAVEZNI USE - CASE - OVI	■ definisanje dozvoljenih algoritama i maksimalnog perioda korišćenja ■ detekcija sredstva koje krši kriptografsku politiku ■ kreiranje plana rotacije sa zavisnim servisima ■ provera da ciljna aplikacija podržava novu verziju/algoritam ■ simulirano aktiviranje nove credential verzije ■ kontrolisano povlačenje stare verzije nakon verifikacije ■ rollback evidencija ako rotacija prekine očekivani servis

R2-19

Kriptografska politika i orchestration rotacije

KLJUČNA POSLOVNA PRAVILA

- rotacija ne sme izlagati tajni materijal u logu ili audit-u
- stara verzija se ne opoziva pre definisane potvrde kada je potreban overlap period
- plan mora imati vlasnika i recovery/rollback korak za kritične sisteme
- crypto policy mora biti verzionisana
- compromised sredstvo može zahtevati ubrzanu rotaciju koja se jasno razlikuje od planirane

MOGUĆA PROŠIRENJA

- mass rotation campaign
- algorithm migration planning
- simulator service-a koji ne podržava novu verziju

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

R2-20

Security baseline drift i remediation

Automatizovano ili simulirano poređenje asset konfiguracije sa bezbednosnim baseline-om i praćenje procesa korekcije.

Element

Specifikacija

Ključni pojmovi

SecurityBaseline, ConfigurationSnapshot, DriftFinding, Remediation, Exception, Verification

Preduslovi

R1-10, R1-16, R1-02, R1-12

OBAVEZNI USE-CASE-OVI

- prijem simuliranog configuration snapshot-a
- evaluacija snapshot-a prema važećem security baseline-u
- otvaranje nalaza za neusaglašenu kontrolu
- dodela remediation vlasnika i roka
- odobravanje vremenski ograničenog izuzetka
- ponovna provera nakon korekcije
- zatvaranje nalaza uz dokaz verifikacije

KLJUČNA POSLOVNA PRAVILA

- baseline mora biti verzionisan i vezan za tip asset-a
- nalaz mora sadržati dovoljno metadata za reprodukciju bez otkrivanja tajni
- izuzetak mora imati razlog, vlasnika i datum isteka
- zatvaranje zahteva novu proveru ili drugi prihvatljiv dokaz
- kritični drift može povećati risk score ali ne sme automatski menjati procenu bez dokumentovane formule

MOGUĆA PROŠIRENJA

- compliance score
- bulk remediation campaign
- integration sa change management simulatorom

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

R2-21

Consent lifecycle i preference enforcement

Operativni tok kojim se consent/preference odluke proveravaju pri pristupu podacima i propagiraju do consumer procesa.

Element	Specifikacija
Ključni pojmovi	ConsentDecision, PreferenceSnapshot, EnforcementCheck, WithdrawalEvent, ProcessingBlock
Preduslovi	R1-21, R1-07, R1-09
OBAVEZNI USE-CASE-OVI	■ evaluacija da li je obrada dozvoljena za svrhu ■ blokiranje obrade nakon povlačenja consent-a ■ kreiranje withdrawal event-a ■ propagacija promene preference-a ka consumer adapteru ■ audit allow/deny odluke ■ pregled procesa pogođenih povlačenjem consent-a
KLJUČNA BEZBEDNOSNA PRAVILA	■ withdrawal mora proizvesti proverljiv security/privacy event ■ stari consent snapshot ne sme validirati novu svrhu ■ obrada bez poznatog osnova mora dobiti determinističan deny ili requires-review ishod ■ consumer ne sme dobiti više podataka nego što je potrebno za enforcement
MOGUĆA PROŠIRENJA	■ preference sync simulator ■ grace-period pravila ■ privacy dashboard
DOKAZ ZAVRŠETKA:	Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

R2-22

Security training campaign workflow

Planiranje, izvršavanje i praćenje awareness kampanje sa kontrolisanim obaveštenjima i dokazima završetka.

Element	Specifikacija
Ključni pojmovi	TrainingCampaign, AssignmentBatch, Reminder, CompletionEvidence, CampaignStatus
Preduslovi	R1-22, R1-11, R1-09
OBAVEZNI USE-CASE-OVI	■ kreiranje kampanje za ciljnu grupu ■ generisanje assignment-a ■ slanje simuliranog reminder-a ■ praćenje statusa po korisniku ■ eskalacija ka odgovornoj grupi za kašnjenja ■ zatvaranje kampanje uz izveštaj
KLJUČNA BEZBEDNOSNA PRAVILA	■ kampanja mora imati scope, rok i owner-a ■ reminder ne sme izlagati osetljive detalje drugim korisnicima ■ status završetka mora referencirati verziju modula ■ kampanja ne sme koristiti realne phishing linkove ili obmanjujuću infrastrukturu

R2-22

Security training campaign workflow

MOGUĆA PROŠIRENJA

- adaptive reminders
- awareness trend
- role-based campaign templates

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

R2-23

Policy exception workflow i compensating controls

Kontrolisani proces od zahteva za policy izuzetak do odluke, compensating control-a i isteka.

Element

Specifikacija

Ključni pojmovi

ExceptionRequest, ApprovalDecision, CompensatingControl, ExpiryReview, ExceptionRisk

Preduslovi

R1-23, R1-16, R1-09

OBAVEZNI USE-CASE-OVI

- otvaranje zahteva za izuzetak
- dodela rizika i compensating control-a
- odobravanje ili odbijanje zahteva
- obaveštenje pred istek izuzetka
- periodična re-evaluacija aktivnih izuzetaka
- zatvaranje izuzetka i verifikacija stanja

KLJUČNA BEZBEDNOSNA PRAVILA

- odobren izuzetak mora imati rok isteka
- compensating control mora biti povezan sa konkretnom kontrolom ili gap-om
- istek izuzetka mora proizvesti jasno operativno stanje
- neodobren zahtev ne sme menjati status kontrole

MOGUĆA PROŠIRENJA

- multi-step approval
- exception review board simulator
- risk acceptance paket

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

R2-24

Service-account review i stale-credential cleanup

Periodična provera non-human identiteta, njihovih owner-a i credential metadata radi uklanjanja zastarelih ili preširokih prava.

Element	Specifikacija
Ključni pojmovi	ServiceAccountReview, StaleCredential, ScopeFinding, CleanupAction, ReviewOutcome
Preduslovi	R1-24, R2-04, R2-05
OBAVEZNI USE-CASE-OVI	▪ pokretanje review kampanje za service account-e ▪ identifikacija naloga bez owner-a ili aktivnosti ▪ detekcija preširokog scope-a ▪ predlog rotacije ili deaktivacije credential-a ▪ potvrda owner-a ili cleanup akcije ▪ audit review ishoda
KLJUČNA BEZBEDNOSNA PRAVILA	▪ cleanup ne sme automatski obrisati tajnu bez kontrolisane odluke ▪ stale status mora imati kriterijum i podatke na osnovu kojih je utvrđen ▪ owner mora potvrditi poslovnu svrhu kritičnog service account-a ▪ review ishod mora biti auditabilan
MOGUĆA PROŠIRENJA	▪ attestation workflow ▪ risk score za non-human identity ▪ bulk credential rotation candidate list
DOKAZ ZAVRŠETKA:	Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

R2-25

Session anomaly i impossible-travel detection

Detekcija neuobičajenih sesijskih obrazaca kroz objašnjiva pravila i kontrolisane simulirane podatke.

Element	Specifikacija
Ključni pojmovi	SessionAnomaly, LoginEvent, GeoVelocity, DeviceChange, AnomalyFinding
Preduslovi	R2-02, R2-17, R1-13
OBAVEZNI USE-CASE-OVI	▪ prijem login/session događaja ▪ evaluacija impossible-travel pravila ▪ detekcija nagle promene uređaja ili lokacije ▪ generisanje anomaly finding-a ▪ povezivanje nalaza sa korisnikom i sesijom ▪ potvrda, odbacivanje ili eskalacija nalaza
KLJUČNA BEZBEDNOSNA PRAVILA	▪ nalaz je indikacija, ne dokaz kompromitacije ▪ pravila moraju biti deterministička za iste ulaze ▪ nedostajući geo/device podaci moraju biti označeni kao unknown ▪ eskalacija ne sme izlagati nepotrebne podatke analitičaru bez scope-a

R2-25**Session anomaly i impossible-travel detection****MOGUĆA PROŠIRENJA**

- adaptive threshold
- link ka incident triage-u
- false-positive feedback

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

R2-26**Device quarantine i access restriction workflow**

Operativno ograničavanje pristupa uređaju ili endpoint-u kada posture ili incident signal ukazuje na rizik.

Element**Specifikacija****Ključni pojmovi**

QuarantineCase, AccessRestriction, DevicePosture, ReleaseDecision, RestrictionScope

Preduslovi

R1-26, R2-14, R2-08

OBAVEZNI USE-CASE-OVI

- otvaranje quarantine slučaja
- primena simulirane access restriction odluke
- obaveštavanje owner-a uređaja
- verifikacija poboljšanja posture-a
- release iz quarantine stanja
- audit odluke i scope-a ograničenja

KLJUČNA BEZBEDNOSNA PRAVILA

- quarantine mora imati razlog, scope i rok ili uslov izlaska
- release mora imati dokaz ili odobrenje
- ograničenje ne sme blokirati širi scope od definisanog bez odluke
- nepoznat uređaj ne sme automatski dobiti trusted status

MOGUĆA PROŠIRENJA

- MDM adapter simulator
- temporary exception
- quarantine dashboard

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

R2-27

Evidence collection package i handoff workflow

Kreiranje kontrolisanog evidence paketa za incident, audit ili kontrolu, uključujući minimalne dokaze i chain-of-custody.

Element	Specifikacija
Ključni pojmovi	EvidencePackage, Handoff, EvidenceManifest, IntegrityCheck, RecipientScope
Preduslovi	R1-27, R2-10, R2-09
OBAVEZNI USE-CASE-OVI	- formiranje evidence paketa - izbor relevantnih evidence item-a - generisanje manifesta i integrity metadata - kontrolisana predaja ovlašćenom primaocu - evidencija pristupa i preuzimanja - verifikacija paketa nakon handoff-a
KLJUČNA BEZBEDNOSNA PRAVILA	- paket ne sme sadržati dokaze van scope-a slučaja - svaki pristup paketu mora biti auditovan - manifest mora omogućiti proveru integriteta bez izlaganja tajni - handoff mora imati primaoca, vreme i svrhu
MOGUĆA PROŠIRENJA	- export u arhivu - redaction workflow - legal-hold metadata kao edukativno proširenje
DOKAZ ZAVRŠETKA:	Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

R2-28

Incident playbook execution tracking

Praćenje izvršenja playbook koraka tokom incidenta, sa odgovornostima, evidence-om i odstupanjima.

Element	Specifikacija
Ključni pojmovi	PlaybookRun, StepExecution, ManualApproval, Deviation, StepEvidence
Preduslovi	R1-28, R2-09, R2-10
OBAVEZNI USE-CASE-OVI	- pokretanje playbook-a nad incidentom - dodela koraka odgovornim ulogama - evidencija izvršenja ili preskakanja koraka - traženje ručnog odobrenja za osetljiv korak - prikupljanje evidence-a po koraku - zatvaranje playbook run-a sa odstupanjima
KLJUČNA BEZBEDNOSNA PRAVILA	- preskočen korak mora imati razlog - oštećujuća ili privilegovana akcija mora imati approval ili safety check - playbook run koristi verziju playbook-a važeću u trenutku pokretanja - automatski korak ne sme izvršiti realnu destruktivnu akciju u studentskom okruženju

R2-28

Incident playbook execution tracking

MOGUĆA PROŠIRENJA

- SLA po koraku
- runbook timeline
- post-incident improvement task

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

R2-29

Crown-jewel access monitoring

Praćenje pristupa kritičnim asset-ima i podacima, sa posebnim pravilima za detekciju i audit.

Element

Specifikacija

Ključni pojmovi

CriticalAccessEvent, CrownJewelPolicy, AccessPattern, MonitoringRule, OwnerNotification

Preduslovi

R1-29, R1-06, R2-17

OBAVEZNI USE-CASE-OVI

- identifikacija pristupa crown-jewel resursu
- primena posebnih monitoring pravila
- generisanje događaja za neuobičajen pristup
- obaveštavanje owner-a kada politika to zahteva
- pregled istorije pristupa po resursu
- povezivanje događaja sa incident/risk stavkom

KLJUČNA BEZBEDNOSNA PRAVILA

- kritičan resurs mora imati jasnu politiku monitoringa ili evidentiran gap
- monitoring ne sme čuvati nepotrebni sadržaj podataka
- owner notification mora poštovati scope i klasifikaciju
- pristup dozvoljenom korisniku i dalje može biti auditovan bez automatske optužbe

MOGUĆA PROŠIRENJA

- behavior baseline
- owner attestation
- high-value asset dashboard

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Operativno prikupljanje izjava owner-a o statusu kontrola i praćenje nedostajućih ili negativnih odgovora.

Element	Specifikacija
Ključni pojmovi	ControlAttestation, OwnerResponse, FollowUpAction, AttestationPeriod, ControlStatus
Preduslovi	R1-30, R3-07, R1-09
OBAVEZNI USE-CASE-OVI	■ pokretanje attestation perioda ■ slanje zahteva owner-u kontrole ■ evidencija potvrde ili izuzetka ■ eskalacija neodgovorenih zahteva ■ povezivanje odgovora sa evidence-om ■ zatvaranje perioda sa gap izveštajem
KLJUČNA BEZBEDNOSNA PRAVILA	■ attestation mora referencirati kontrolu, owner-a i period ■ potvrda bez evidence-a mora biti označena kao self-attested ■ neodgovoren zahtev ne sme se tretirati kao pozitivna potvrda ■ promena owner-a tokom perioda mora biti sledljiva
MOGUĆA PROŠIRENJA	■ campaign templates ■ risk-based sampling ■ dashboard owner coverage
DOKAZ ZAVRŠETKA:	Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Projektne celine nivoa R3

Celine R3 uvode policy/risk orkestraciju, složenije odluke, correlation i automatizovanu reakciju.

R3-01 Policy engine i atributska autorizacija	70	R3-02 Periodic access review i certification	70
R3-03 Risk register i procena bezbednosnog rizika	71	R3-04 Threat modeling workflow	71
R3-05 Security event correlation i analytics	72	R3-06 Automatizacija containment i response akcija	73
R3-07 Compliance evidence i control mapping	73	R3-08 Security exceptions i risk acceptance	74
R3-09 Post-incident review i security improvement tracking	74	R3-10 Attack-path i exposure graph analiza	75
R3-11 Third-party i supplier security assessment	76	R3-12 Continuous control effectiveness i security posture	76
R3-13 Segregation of duties i toxic-access analiza	77	R3-14 Risk-based adaptive authentication	78
R3-15 Detection engineering, simulacija i tuning pravila	78	R3-16 Data-access anomaly i exfiltration risk analitika	79
R3-17 Software provenance i release trust verifikacija	80	R3-18 Privacy impact i data-processing assessment	80
R3-19 Cryptographic posture i migration planning	81	R3-20 Security metrics, risk quantification i executive posture	82
R3-21 Data-subject request i privacy rights workflow	82	R3-22 Human-risk analytics i targeted awareness planning	83
R3-23 Exception portfolio risk analytics	84	R3-24 Non-human identity posture analytics	84
R3-25 Identity threat hunting notebook	85	R3-26 Zero-trust readiness i maturity assessment	86
R3-27 Evidence quality scoring i audit readiness	86	R3-28 Security automation governance	87
R3-29 Crown-jewel risk scenario analysis	88	R3-30 Control assurance roadmap i gap planning	89

R3-01

Policy engine i atributska autorizacija

Donošenje odluke o pristupu na osnovu kombinacije identiteta, resursa, konteksta i politike.

Element	Specifikacija
Ključni pojmovi	PolicyDecision, SubjectAttribute, ResourceAttribute, EnvironmentContext, DecisionReason
Preduslovi	R1-06, R1-07, R1-08
OBAVEZNI USE-CASE-OVI	■ evaluacija politike ■ kombinovanje atributa ■ objašnjenje allow/deny razloga ■ verzionisanje policy seta ■ testiranje policy scenarija
KLJUČNA BEZBEDNOSNA PRAVILA	■ policy engine mora imati determinističke rezultate za isti kontekst ■ deny-by-default mora biti eksplicitna odluka gde je primenjena ■ nejasan/konfliktan policy mora imati definisano pravilo prioriteta
MOGUĆA PROŠIRENJA	■ ABAC ■ risk-aware policy ■ policy simulation
DOKAZ ZAVRŠETKA.	Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R3-02

Periodic access review i certification

Periodična provera da li korisnici i servisi i dalje treba da imaju dodeljena prava.

Element	Specifikacija
Ključni pojmovi	AccessReview, ReviewItem, Reviewer, CertificationDecision, ReviewPeriod
Preduslovi	R1-05, R2-03, R2-04
OBAVEZNI USE-CASE-OVI	■ kreiranje review kampanje ■ generisanje stavki ■ potvrda/ukidanje prava ■ praćenje review statusa ■ zatvaranje kampanje
KLJUČNA BEZBEDNOSNA PRAVILA	■ review ne sme automatski potvrditi pristup zbog neaktivnosti reviewera ■ privilegovana prava imaju stroži review ■ odluka mora biti auditovana

R3-02

Periodic access review i certification

MOGUĆA PROŠIRENJA

- manager review
- owner review
- continuous certification

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R3-03

Risk register i procena bezbednosnog rizika

Povezivanje asset-a, pretnje, slabosti i kontrola u strukturisan risk model.

Element

Specifikacija

Ključni pojmovi

Risk, Threat, Weakness, Impact, Likelihood, ResidualRisk

Preduslovi

R1-02, R2-11

OBAVEZNI USE -
CASE - OVI

- kreiranje rizika
- procena impact/likelihood
- povezivanje kontrole
- izračun rezidualnog rizika
- prihvatanje/mitigacija

KLJUČNA
BEZBEDNOSNA
PRAVILA

- risk score nije zamena za obrazloženje
- promena asset kritičnosti mora pokrenuti reviziju relevantnog rizika
- risk acceptance zahteva owner-a i period pregleda

MOGUĆA PROŠIRENJA

- risk matrix
- treatment plan
- risk appetite

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R3-04

Threat modeling workflow

Sistematsko evidentiranje trust granica, pretnji i planiranih kontrola za aplikacione celine.

Element

Specifikacija

Ključni pojmovi

ThreatModel, TrustBoundary, DataFlow, Threat, Mitigation

Preduslovi

R1-02, R3-03

OBAVEZNI USE -
CASE - OVI

- kreiranje threat model-a
- evidencija trust granice
- povezivanje pretnje sa asset-om/tokom
- dodela mitigacije
- review modela nakon promene

R3-04

Threat modeling workflow

KLJUČNA
BEZBEDNOSNA
PRAVILA

- threat model mora biti vezan za konkretan sistem/tok
- mitigacija mora imati proverljiv zahtev
- model se revidira nakon značajne arhitektonske promene

MOGUĆA PROŠIRENJA

- STRIDE-like category metadata
- diagram attachment
- change-triggered review

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R3-05

Security event correlation i analytics

Kombinovanje više događaja u objašnjivu bezbednosnu sliku bez obaveznog ML-a.

Element

Specifikacija

Ključni pojmovi

CorrelationRule, EventWindow, EntityKey, CorrelationResult, Confidence

Preduslovi

R1-09, R2-07

OBAVEZNI USE-
CASE-OVI

- korelacija više event tipova
- grupisanje po identitetu/asset-u
- vremenski prozor
- izračun objašnjivog confidence-a
- eskalacija u alert

KLJUČNA
BEZBEDNOSNA
PRAVILA

- correlation pravilo mora biti testabilno i objašnjivo
- nedostajući događaj se ne izmišlja
- confidence nije dokaz incidenta

MOGUĆA PROŠIRENJA

- session/entity graph
- behavior baseline
- simple anomaly score

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R3-06

Automatizacija containment i response akcija

Kontrolisana primena bezbednosnih akcija odgovora uz zaštitu od pogrešne automatizacije.

Element	Specifikacija
Ključni pojmovi	ResponseAction, Playbook, ApprovalMode, ActionOutcome, RollbackRef
Preduslovi	R2-02, R2-09, R2-05
OBAVEZNI USE - CASE - OVI	■ predlog containment akcije ■ ručno/automatsko odobrenje ■ ukidanje sesije ■ privremena suspenzija identiteta ■ revoke credential-a ■ evidencija ishoda
KLJUČNA BEZBEDNOSNA PRAVILA	■ destruktivna ili široka akcija zahteva viši nivo odobrenja ■ automatizacija mora biti idempotentna gde je moguće ■ response akcija mora ostaviti audit trag i mogućnost rollback-a kada je relevantno
MOGUĆA PROŠIRENJA	■ playbook engine ■ approval tiers ■ safe dry-run
DOKAZ ZAVRŠETKA.	Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R3-07

Compliance evidence i control mapping

Povezivanje bezbednosnih kontrola sa tehničkim dokazima i periodima važenja.

Element	Specifikacija
Ključni pojmovi	Control, Requirement, EvidenceRef, Assessment, ComplianceStatus
Preduslovi	R1-08, R1-09
OBAVEZNI USE - CASE - OVI	■ definisanje kontrole ■ povezivanje sa policy-em ■ dodavanje dokaza ■ procena stanja ■ periodični review
KLJUČNA BEZBEDNOSNA PRAVILA	■ compliance status nije isto što i odsustvo rizika ■ dokaz mora imati izvor i period važenja ■ istekao dokaz ne smatra se automatski važećim

R3-07

Compliance evidence i control mapping

MOGUĆA PROŠIRENJA

- control framework mapping
- evidence automation
- assessment campaign

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R3-08

Security exceptions i risk acceptance

Formalno upravljanje odstupanjima od politika ili baseline-a uz vlasnika, rok i rizik.

Element

Specifikacija

Ključni pojmovi

SecurityException, PolicyRef, RiskRef, Owner, ExpiresAt

Preduslovi

R1-08, R1-10, R3-03

OBAVEZNI USE-CASE-OVI

- podnošenje izuzetka
- odobravanje/odbijanje
- povezivanje sa rizikom
- istek izuzetka
- obnova uz novu procenu

KLJUČNA BEZBEDNOSNA PRAVILA

- izuzetak ne briše osnovnu politiku
- svaki izuzetak ima rok
- istekao izuzetak vraća status u neusaglašeno stanje ako problem ostaje

MOGUĆA PROŠIRENJA

- temporary compensating control
- exception SLA
- bulk review

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R3-09

Post-incident review i security improvement tracking

Pretvaranje iskustva iz incidenta u merljive korektivne i preventivne akcije.

Element

Specifikacija

Ključni pojmovi

PostIncidentReview, Finding, ActionItem, Owner, DueDate

Preduslovi

R2-09, R2-10

OBAVEZNI USE-CASE-OVI

- pokretanje review-a
- evidencija root cause-a na odgovarajućem nivou
- definisanje akcija
- praćenje realizacije
- zatvaranje uz verifikaciju

R3-09

Post-incident review i security improvement tracking

KLJUČNA
BEZBEDNOSNA
PRAVILA

- PIR nije mesto za pripisivanje krivice pojedincu
- akcija mora imati owner-a i rok
- incident se može zatvoriti operativno pre završetka svih improvement akcija, ali one ostaju sledljive

MOGUĆA PROŠIRENJA

- trend findings
- recurrent incident link
- control effectiveness review

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R3-10

Attack-path i exposure graph analiza

Defanzivna analiza mogućih puteva od ulazne tačke do kritičnog asset-a na osnovu poznatih trust, vulnerability i privilege veza, bez izvođenja realnog napada.

Element

Specifikacija

Ključni pojmovi

AttackPath, ExposureEdge, EntryPoint, PrivilegeStep, CriticalAsset, Mitigation

Preduslovi

R1-02, R1-14, R2-11, R3-04

OBAVEZNI USE-
CASE-OVI

- izgradnja exposure grafa iz asset, trust-boundary i vulnerability podataka
- pronalaženje mogućih puteva ka kritičnom asset-u
- rangiranje puta prema broju koraka, kritičnosti i poznatim slabostima
- what-if uklanjanje vulnerability ili trust veze radi procene mitigacije
- dodela vlasnika i remediation akcije za visokorizičan put
- periodično ponovno izračunavanje nakon promene inventara

KLJUČNA
BEZBEDNOSNA
PRAVILA

- attack-path je analitički model i ne sme automatski dokazivati da je exploit moguć
- kritičnost i confidence ulaznih podataka moraju biti vidljivi
- nepoznata veza ne sme se implicitno tretirati kao bezbedna
- analiza se izvodi isključivo nad sopstvenim registrima i simulatorima

MOGUĆA PROŠIRENJA

- graph centrality/risk heuristika
- attack-path diff između dve verzije sistema
- mapiranje mitigacije na security controls

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R3-11

Third-party i supplier security assessment

Upravljanje bezbednosnim procenama dobavljača i eksternih servisa koji imaju uticaj na interne asset-e ili podatke.

Element	Specifikacija
Ključni pojmovi	ThirdParty, SupplierService, Assessment, Finding, AssuranceEvidence, RiskDecision
Preduslovi	R1-02, R1-16, R3-03
OBAVEZNI USE-CASE-OVI	- registracija third-party organizacije i usluge - povezivanje dobavljača sa internim asset-ima i data klasama - pokretanje periodične security procene - evidencija nalaza, dokaza i rokova za odgovor - risk acceptance ili remediation odluka za značajan nalaz - praćenje isteka assessment-a i potrebe za ponovnom proverom
KLJUČNA BEZBEDNOSNA PRAVILA	- third-party assessment mora imati vlasnika i datum važenja - dobavljački dokaz ne sme automatski zatvoriti interni risk bez review-a - poverljivi dokumenti se modeluju metapodacima ili bezbednim test artefaktima - kritična usluga sa isteklom procenom mora biti vidljiva kao risk signal
MOGUĆA PROŠIRENJA	- standardized questionnaire template - supplier tiering - contract/security obligation tracking
DOKAZ ZAVRŠETKA.	Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R3-12

Continuous control effectiveness i security posture

Analitika koja povezuje kontrole, testove, događaje i evidence kako bi se procenila aktuelnost i efektivnost bezbednosnih mera kroz vreme.

Element	Specifikacija
Ključni pojmovi	ControlMetric, ControlTestResult, Coverage, EffectivenessScore, EvidenceFreshness, PostureTrend
Preduslovi	R1-16, R3-05, R3-07
OBAVEZNI USE-CASE-OVI	- prijem rezultata kontrolnih testova ili verifikovanih evidence signala - izračunavanje coverage-a po kontroli i asset scope-u - detekcija zastarelog ili nedostajućeg dokaza - računanje verzionisanog effectiveness score-a sa objašnjivim faktorima - trend pregled poboljšanja/pogoršanja posture-a - drill-down sa agregata do konkretnog failed testa ili evidence zapisa
KLJUČNA BEZBEDNOSNA PRAVILA	- missing evidence ne sme biti tretiran kao pass - score formula mora biti dokumentovana, verzionisana i reproduktibilna - agregatni score ne sme sakriti otvoren kritičan nalaz - analytics komponenta ne menja automatski risk acceptance ili incident odluku

R3-12

Continuous control effectiveness i security posture

MOGUĆA PROŠIRENJA

- control heat-map
- SLA za evidence freshness
- what-if posture nakon planirane mitigacije

DOKAZ ZAVRŠETKA.

Celina mora imati izvršive ključne use-case-ove, automatizovane testove, dokumentovanu granicu poverenja prema drugim celinama i najmanje jedan reprezentativan negativni ili abuse-case scenario.

R3-13

Segregation of duties i toxic-access analiza

Analiza kombinacija uloga, privilegija i vlasništva radi detekcije nedozvoljenih ili rizičnih koncentracija ovlašćenja.

Element

Specifikacija

Ključni pojmovi

SodRule, ToxicCombination, EntitlementSet, ConflictFinding, Mitigation, CompensatingControl

Preduslovi

R1-05, R1-06, R2-03, R3-02

OBAVEZNI USE-CASE-OVI

- definisanje SoD pravila i zabranjenih kombinacija
- izračunavanje efektivnih privilegija korisnika
- detekcija toxic combination nalaza
- procena uticaja privremenog JIT granta na SoD
- predlaganje uklanjanja privilegije ili compensating kontrole
- odobravanje vremenski ograničenog izuzetka
- periodična reevaluacija nakon promene uloga

KLJUČNA POSLOVNA PRAVILA

- nalaz mora biti zasnovan na efektivnim, ne samo direktno dodeljenim privilegijama
- JIT privilegija se uključuje u analizu tokom perioda važenja
- izuzetak mora imati vlasnika, razlog i rok
- sistem ne sme automatski ukidati pristup bez definisanog approval procesa
- pravilo i rezultat moraju biti reprodukovljivi uz verziju policy-ja

MOGUĆA PROŠIRENJA

- graf entitlement zavisnosti
- role mining preporuke
- high-risk combination dashboard

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Dinamička odluka o potrebnom nivou autentikacije na osnovu konteksta prijave i verzionisane risk politike.

Element	Specifikacija
Ključni pojmovi	AuthenticationRisk, ContextSignal, RiskPolicy, StepUpDecision, TrustedContext, RiskOutcome
Preduslovi	R2-01, R2-02, R2-14, R1-08
OBAVEZNI USE - CASE - OVI	- prikupljanje dozvoljenih kontekstualnih signala iz simuliranog login zahteva - izračunavanje risk score-a prema objašnljivoj politici - dozvola standardne autentikacije za nizak rizik - zahtev za step-up faktor pri povećanom riziku - blokada ili dodatna provera visokorizičnog pokušaja - evidencija odluke i relevantnih signala bez nepotrebnog čuvanja osetljivih podataka - naknadna analiza false-positive/false-negative scenarija
KLJUČNA POSLOVNA PRAVILA	- odluka mora biti deterministička ili reprodukovljiva za isti context snapshot - osetljivi signali se minimizuju i čuvaju samo koliko je potrebno - risk score ne zamenjuje server-side authorization - nedostajući signal ne sme automatski značiti nizak rizik - promena risk politike ne menja istorijsku odluku
MOGUĆA PROŠIRENJA	- geo-velocity simulator - trusted device weighting - user notification za rizičnu prijavu
DOKAZ ZAVRŠETKA:	Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Životni ciklus detection pravila od predloga preko simulacije na kontrolisanim događajima do merenja kvaliteta i produkcionog odobrenja.

Element	Specifikacija
Ključni pojmovi	DetectionRuleVersion, TestCorpus, DetectionRun, TruePositive, FalsePositive, Coverage, TuningDecision
Preduslovi	R2-07, R2-17, R1-12
OBAVEZNI USE - CASE - OVI	- kreiranje nove verzije detection pravila - definisane kontrolisanog test corpus-a simuliranih događaja - izvršavanje pravila nad corpus-om - izračunavanje osnovnih quality metrika - poređenje dve verzije pravila - odobravanje/promocija izabrane verzije - evidencija tuning odluke i razloga

R3-15

Detection engineering, simulacija i tuning pravila

KLJUČNA POSLOVNA PRAVILA

- test corpus ne sme sadržati stvarne tajne ili tuđe osetljive podatke
- promena rule verzije mora biti sledljiva
- quality metrika mora imati jasno definisan skup očekivanih rezultata
- pravilo sa lošijim rezultatom ne sme automatski zameniti aktivnu verziju bez eksplicitne odluke
- simulacija ne sme kreirati stvarne containment akcije

MOGUĆA PROŠIRENJA

- coverage po ATT&CK-like kategoriji bez obaveznog spoljnog feed-a
- shadow evaluation
- regression suite za detection rules

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

R3-16

Data-access anomaly i exfiltration risk analitika

Analiza bezbednosnih metapodataka o pristupu klasifikovanim podacima radi prepoznavanja neuobičajenih obrazaca bez potrebe za čuvanjem samog sadržaja.

Element

Specifikacija

Ključni pojmovi

AccessPattern, Baseline, AnomalySignal, ExfiltrationRisk, PeerGroup, InvestigationCandidate

Preduslovi

R1-07, R2-15, R2-17, R3-05

OBAVEZNI USE-CASE-OVI

- agregacija access metadata po korisniku, resursu i periodu
- izgradnja jednostavnog objašnjivog baseline-a
- detekcija neuobičajenog obima ili destination obrasca
- kombinovanje sa klasifikacijom podatka i trust zonom
- generisanje investigation kandidata sa razlozima
- suppress/close odluka uz obrazloženje
- periodična reevaluacija baseline-a bez retroaktivnog menjanja nalaza

KLJUČNA POSLOVNA PRAVILA

- anomalija nije dokaz incidenta i mora biti označena kao signal
- analitika koristi minimizovane metadata podatke, ne puni sadržaj
- baseline mora čuvati period i verziju metode
- nov korisnik ili nedovoljno podataka mora imati eksplicitan cold-start ishod
- tenant/security-domain scope mora biti poštovan

MOGUĆA PROŠIRENJA

- peer-group poređenje
- seasonality po radnom vremenu
- risk score sa DLP događajima

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Procena poverenja u softverski release na osnovu dependency inventara, build provenance metadata, approval-a i poznatih security nalaza.

Element	Specifikacija
Ključni pojmovi	ReleaseArtifact, ProvenanceAttestation, BuildIdentity, DependencySnapshot, TrustPolicy, ReleaseDecision
Preduslovi	R2-13, R2-11, R1-16
OBAVEZNI USE-CASE-OVI	▪ registracija release artefakta i build provenance metadata ▪ povezivanje release-a sa dependency/SBOM snapshot-om ▪ provera obaveznih build/approval dokaza prema trust policy-ju ▪ evaluacija poznatih kritičnih vulnerability nalaza u dependency-jima ▪ donošenje allow/warn/block release odluke ▪ odobravanje kontrolisanog izuzetka uz rok ▪ ponovna evaluacija nakon pojave novog dependency nalaza
KLJUČNA POSLOVNA PRAVILA	▪ odsustvo provenance dokaza ne sme biti predstavljeno kao potvrđena bezbednost ▪ trust odluka mora referencirati verziju policy-ja i dependency snapshot ▪ izuzetak ne uklanja izvorni finding ▪ release odluka ne sme zavisiti od mutable taga bez stabilnog digest/identiteta ▪ pristup detaljima build sistema mora poštovati scope
MOGUĆA PROŠIRENJA	▪ signed attestation metadata ▪ release promotion gate ▪ provenance chain visualization
DOKAZ ZAVRŠETKA:	Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Strukturisana procena rizika obrade ličnih ili posebno osetljivih podataka na osnovu data-flow registra, svrhe, klasifikacije i kontrola.

Element	Specifikacija
Ključni pojmovi	ProcessingActivity, PrivacyRisk, Purpose, DataSubjectCategory, Mitigation, AssessmentVersion
Preduslovi	R1-07, R1-20, R3-03, R1-16
OBAVEZNI USE-CASE-OVI	▪ registracija processing aktivnosti i poslovne svrhe ▪ identifikacija kategorija podataka i tokova koji učestvuju ▪ procena privacy/security rizika prema definisanoj metodologiji ▪ povezivanje postojećih kontrola i gap-ova ▪ definisanje mitigation aktivnosti i vlasnika ▪ odobravanje procene i periodične reevaluacije ▪ otvaranje nove verzije procene nakon značajne promene data flow-a

KLJUČNA POSLOVNA PRAVILA

- procena mora čuvati verziju metodologije i ulazni scope
- svrha obrade mora biti eksplicitna i ne može biti naknadno tiho proširena
- assessment ne sme sadržati stvarne lične podatke kada nisu potrebni
- nepoznat tok osetljivih podataka mora biti evidentiran kao gap
- zatvorena procena ostaje istorijski sledljiva

MOGUĆA PROŠIRENJA

- privacy control mapping
- data minimization checklist
- assessment diff između verzija

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Analitički pregled kriptografske izloženosti organizacije i planiranje prelaska sa zastarelih algoritama, ključeva ili sertifikacionih profila.

Element

Specifikacija

Ključni pojmovi

CryptoPosture, AlgorithmRisk, ExpiryForecast, MigrationWave, DependencyImpact, CryptoDebt

Preduslovi

R1-17, R2-19, R3-10

OBAVEZNI USE-CASE-OVI

- agregacija crypto asset-a po algoritmu, starosti i kritičnosti
- detekcija zastarelih ili uskoro nevažećih profila
- impact analiza servisa zavisnih od određenog algoritma/credential tipa
- grupisanje migracije u kontrolisane talase
- procena prioriteta prema kritičnosti i exposure-u
- praćenje napretka migration plana
- recalculacija posture-a nakon završene rotacije

KLJUČNA POSLOVNA PRAVILA

- posture score mora imati dokumentovanu formulu
- nepoznat algoritam ili metadata mora biti označen kao gap
- migration plan ne sme automatski rotirati produkcione credential-e
- istorijska procena mora ostati reproduktibilna
- prioritet mora uzeti u obzir i poslovni impact, ne samo tehničku zastarelost

MOGUĆA PROŠIRENJA

- crypto-agility dashboard
- what-if deprecation scenario
- expiry concentration heatmap

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Konzistentan skup bezbednosnih KPI/KRI pokazatelja koji povezuje rizike, incidente, kontrolne nalaze i remediation trendove bez stvaranja lažne preciznosti.

Element	Specifikacija
Ključni pojmovi	SecurityMetric, KRI, KPI, RiskTrend, MetricSnapshot, Confidence, PostureReport
Preduslovi	R3-03, R3-05, R3-07, R3-12
OBAVEZNI USE-CASE-OVI	- definisane metrike sa formulom, izvorima i owner-om - periodični snapshot bezbednosnih KPI/KRI vrednosti - trend otvorenih high-risk nalaza i remediation vremena - agregacija control effectiveness i incident podataka - prikaz confidence/data-quality oznake uz metriku - generisanje executive posture izveštaja sa drill-down izvorima - verzionisanje definicije metrike bez izmene istorijskih snapshot-a
KLJUČNA POSLOVNA PRAVILA	- svaka metrika mora imati jasno definisanu formulu i izvor - nedostajući podaci ne smeju se automatski tretirati kao nula - agregirani score mora prikazati ograničenja i confidence - istorijski snapshot koristi definiciju koja je važila tada - izveštaj mora poštovati security-domain i role scope
MOGUĆA PROŠIRENJA	- weighted risk heatmap - target/threshold tracking - trend forecasting jednostavnom objašnjivom metodom
DOKAZ ZAVRŠETKA:	Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Koordinacija zahteva subjekta podataka kroz data-flow, consent i evidence evidencije bez pravnog sertifikovanja sistema.

Element	Specifikacija
Ključni pojmovi	DataSetRequest, RequestType, VerificationStatus, FulfillmentTask, ResponsePackage
Preduslovi	R1-21, R1-20, R2-18
OBAVEZNI USE-CASE-OVI	- otvaranje data-subject zahteva - verifikacija identiteta kroz kontrolisan status - pronalaženje relevantnih tokova i skladišta podataka - kreiranje fulfillment zadataka po sistemu - generisanje minimalnog response paketa - zatvaranje zahteva uz audit

KLJUČNA
BEZBEDNOSNA
PRAVILA

- zahtev ne sme biti obrađen bez verifikacije identiteta ili odgovarajućeg statusa
- response paket mora poštovati klasifikaciju i scope
- brisanje/izmena podataka ne sme biti simulirana kao pravna garancija bez obeležavanja ograničenja
- svaki korak mora biti auditabilan

MOGUĆA PROŠIRENJA

- SLA tracking
- redaction preview
- partial fulfillment reason

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Analitika human-risk signala iz treninga, incidenata i policy nalaza radi planiranja ciljane edukacije bez profilisanja van dometa projekta.

Element

Specifikacija

Ključni pojmovi

HumanRiskSignal, AwarenessPlan, TargetGroup, RiskFactor, Recommendation

Preduslovi

R1-22, R2-22, R3-05

OBAVEZNI USE-
CASE-OVI

- agregacija awareness i incident signala
- formiranje objašnjivih risk faktora po grupi
- predlog ciljane obuke ili kampanje
- poređenje trendova pre i posle kampanje
- ručna potvrda plana
- čuvanje obrazloženja preporuke

KLJUČNA
BEZBEDNOSNA
PRAVILA

- analitika se koristi na grupnom ili kontrolisanom scope-u, ne za neosnovano etiketiranje pojedinca
- preporuka mora biti objašnjiva
- nedostajući podaci moraju biti označeni kao ograničenje
- plan ne sme automatski slati kampanju bez odobrenja

MOGUĆA PROŠIRENJA

- team-level heatmap
- recommendation confidence
- awareness effectiveness trend

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

R3-23

Exception portfolio risk analytics

Analiza portfolija security izuzetaka, koncentracije rizika, isteka i compensating control kvaliteta.

Element	Specifikacija
Ključni pojmovi	ExceptionPortfolio, RiskConcentration, ExpiryCluster, CompensatingControlQuality, PortfolioTrend
Preduslovi	R1-23, R2-23, R3-03
OBAVEZNI USE - CASE - OVI	■ agregacija aktivnih izuzetaka ■ identifikacija koncentracije po asset-u, kontroli ili owner-u ■ detekcija izuzetaka blizu isteka ■ procena kvaliteta compensating control-a ■ rangiranje izuzetaka za review ■ generisanje portfolio izveštaja
KLJUČNA BEZBEDNOSNA PRAVILA	■ agregirani score mora prikazati formulu i ograničenja ■ istekli izuzetak mora biti posebno označen, ne tiho računat kao važeći ■ risk analiza ne sme automatski odobriti ili ukinuti izuzetak ■ nedostajući podaci umanjuju confidence
MOGUĆA PROŠIRENJA	■ exception debt trend ■ review prioritization ■ control gap mapa
DOKAZ ZAVRŠETKA:	Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

R3-24

Non-human identity posture analytics

Analitika rizika service account-a i machine identity-ja kroz scope, rotaciju, vlasništvo i aktivnost.

Element	Specifikacija
Ključni pojmovi	NhiPosture, ServiceAccountRisk, CredentialAge, ScopeBreadth, OwnerCoverage
Preduslovi	R1-24, R2-24, R3-12
OBAVEZNI USE - CASE - OVI	■ agregacija non-human identity zapisa ■ izračunavanje risk faktora ■ detekcija starih credential-a i orphan naloga ■ poređenje posture-a kroz vreme ■ generisanje preporuka za review/cleanup ■ čuvanje snapshot-a posture-a
KLJUČNA BEZBEDNOSNA PRAVILA	■ risk score mora biti objašnjiv kroz faktore ■ nema automatskog ukidanja identiteta bez workflow-a ■ nepoznata aktivnost ili owner mora biti označena kao rizik/gap ■ snapshot koristi pravila koja su važila tada

R3-24**Non-human identity posture analytics****MOGUĆA PROŠIRENJA**

- identity graph
- rotation plan simulator
- privilege breadth score

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

R3-25**Identity threat hunting notebook**

Kontrolisano okruženje za objašnjive upite i hipoteze nad identity/security događajima, bez realnog napada i bez izlaganja tajni.

Element**Specifikacija****Ključni pojmovi**

HuntingQuery, Hypothesis, Finding, EvidenceLink, QueryVersion

Preduslovi

R2-17, R2-25, R3-05

OBAVEZNI USE-CASE-OVI

- kreiranje hunting hipoteze
- definisanje upita nad normalizovanim događajima
- čuvanje rezultata kao finding-a
- povezivanje finding-a sa evidence/incident zapisom
- verzionisanje upita
- označavanje false-positive ishoda

KLJUČNA BEZBEDNOSNA PRAVILA

- hunting upit ne sme prikazati tajne ili nepotrebni sadržaj
- finding je hipoteza dok se ne potvrdi
- ista verzija upita nad istim podacima mora dati reproduktibilan rezultat
- pristup notebook-u mora poštovati role/scope

MOGUĆA PROŠIRENJA

- query library
- scheduled hunt simulator
- mapping na MITRE tehniku

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Procena zrelosti identiteta, uređaja, trust granica i policy enforcement-a kroz kontrolisan model zrelosti.

Element	Specifikacija
Ključni pojmovi	ZeroTrustCapability, MaturityLevel, Gap, ImprovementPlan, AssessmentSnapshot
Preduslovi	R1-14, R2-14, R3-12
OBAVEZNI USE - CASE - OVI	- definisanje capability modela - prikupljanje evidence-a za zrelost - dodela maturity nivoa po oblasti - identifikacija gap-ova - formiranje improvement plana - čuvanje assessment snapshot-a
KLJUČNA BEZBEDNOSNA PRAVILA	- maturity nivo mora imati kriterijume i evidence - nedostajući evidence ne sme se tretirati kao ispunjenje - assessment je interni edukativni model, ne formalna sertifikacija - promena kriterijuma ne sme retroaktivno menjati stare snapshot-e
MOGUĆA PROŠIRENJA	- radar chart - target maturity planning - benchmark simulator bez realnih tvrdnji
DOKAZ ZAVRŠETKA:	Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Procena kvaliteta dokaza i spremnosti za internu proveru kroz coverage, integritet, chain-of-custody i klasifikaciju.

Element	Specifikacija
Ključni pojmovi	EvidenceQualityScore, CoverageGap, IntegritySignal, AuditReadiness, EvidenceDefect
Preduslovi	R1-27, R3-07, R2-27
OBAVEZNI USE - CASE - OVI	- evaluacija evidence paketa - detekcija nedostajućih dokaza po kontroli - provera integrity i chain-of-custody signala - izračunavanje objašnjivog quality score-a - generisanje gap liste - praćenje poboljšanja readiness-a
KLJUČNA BEZBEDNOSNA PRAVILA	- score mora navesti faktore i ograničenja - nedostajući dokaz ne sme biti tretiran kao pozitivan rezultat - audit readiness nije formalna sertifikacija - samo korisnici sa scope-om mogu videti detalje dokaza

R3-27

Evidence quality scoring i audit readiness

MOGUĆA PROŠIRENJA

- evidence linting
- readiness dashboard
- control-to-evidence traceability matrix

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

R3-28

Security automation governance

Upravljanje automatskim security akcijama kroz dozvole, safety checks, rollback i risk acceptance pre izvršenja.

Element

Specifikacija

Ključni pojmovi

AutomationPolicy, ActionScope, SafetyCheck, RollbackPlan, AutomationDecision

Preduslovi

R1-28, R3-06, R3-08

OBAVEZNI USE-CASE-OVI

- registracija automatizovane security akcije
- definisanje scope-a i safety check-a
- procena rizika pre aktivacije
- ručno odobrenje za osetljive akcije
- evidencija izvršenja i rollback plana
- review automatizacije nakon incidenta

KLJUČNA BEZBEDNOSNA PRAVILA

- automatizacija ne sme izvršiti destruktivnu akciju bez scope-a i safety check-a
- svaka akcija mora biti auditovana
- rollback plan mora postojati za akcije koje menjaju stanje
- failure automatizacije ne sme sakriti stvarni incident status

MOGUĆA PROŠIRENJA

- simulation mode
- approval policy engine
- automation blast-radius estimate

DOKAZ ZAVRŠETKA:

Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Analiza scenarija rizika nad najkritičnijim asset-ima kroz threat, exposure, kontrolu i business impact.

Element	Specifikacija
Ključni pojmovi	RiskScenario, CrownJewelAsset, ThreatPath, ControlGap, ScenarioImpact
Preduslovi	R1-29, R3-03, R3-10
OBAVEZNI USE-CASE-OVI	■ izbor crown-jewel asset-a ■ formiranje threat/risk scenarija ■ povezivanje exposure i kontrolnih gap-ova ■ procena impact-a i verovatnoće kao edukativnog modela ■ poređenje mitigacionih opcija ■ čuvanje scenario snapshot-a
KLJUČNA BEZBEDNOSNA PRAVILA	■ scenario mora razlikovati pretpostavke od činjenica ■ risk score mora biti objašnjiv i ne sme stvarati lažnu preciznost ■ mitigacija ne sme automatski menjati kontrole bez workflow-a ■ nedostajući dependency/exposure podaci moraju biti označeni
MOGUĆA PROŠIRENJA	■ what-if mitigation ■ executive scenario brief ■ scenario library
DOKAZ ZAVRŠETKA:	Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Planiranje poboljšanja kontrola kroz gap analizu, owner-e, prioritete i zavisnosti, bez menjanja ocenjivanja projekta.

Element	Specifikacija
Ključni pojmovi	AssuranceRoadmap, ControlGap, ImprovementInitiative, Dependency, TargetState
Preduslovi	R1-30, R3-12, R3-20
OBAVEZNI USE - CASE - OVI	■ agregacija kontrolnih gap-ova ■ definisanje target state-a ■ prioritizacija improvement inicijativa ■ povezivanje zavisnosti i owner-a ■ formiranje roadmap-a ■ praćenje statusa i dokaza završetka
KLJUČNA BEZBEDNOSNA PRAVILA	■ roadmap stavka mora imati owner-a, razlog i očekivani dokaz ■ prioritet mora biti objašnjiv kroz risk/impact/effort faktore ■ plan ne sme prikazivati gap kao rešen bez evidence-a ■ promena cilja mora ostati auditabilna
MOGUĆA PROŠIRENJA	■ quarterly roadmap view ■ dependency graph ■ risk reduction estimate
DOKAZ ZAVRŠETKA:	Celina mora imati izvršive ključne use-case-ove, automatizovane testove poslovnih pravila, dokumentovanu javnu granicu prema drugim celinama i najmanje jedan reprezentativan demo scenario.

Integracija, bezbednosno testiranje i kriterijumi završetka

10

10.1. Preporučeni integracioni scenariji

Scenario	Uključene oblasti	Očekivani rezultat
Horizontalni pristup tuđem resursu	Identity + RBAC + Object Authorization + Audit	403/deny bez curenja podataka, uz odgovarajući audit događaj
Privilegovana promena uloge	Privileged Access + Step-up + RBAC + Notification	promena se izvršava samo uz aktivan grant i dodatnu potvrdu
Revoked session	Session + Authorization + Audit	ranije validna sesija više ne daje pristup
Rotacija service credential-a	Service Identity + Secrets + Application Simulator	nova verzija postaje aktivna bez izlaganja tajne
Sumnjiv obrazac prijava	Authentication + Events + Detection + Alert	događaji proizvode objašnjiv alert bez automatskog incidenta ako policy to ne traži
Incident i containment	Alert + Incident + Response + Session/Secret Revoke	containment akcija je auditovana i ograničena definisanim scope-om
Vulnerability + risk	Asset + Vulnerability + Risk + Exception	nalaz se povezuje sa poslovnim rizikom i ima remediation/acceptance odluku
Unmanaged uređaj traži pristup	Identity + MFA + Device Posture + Policy	pristup dobija deterministički ishod uz audit bez implicitnog poverenja uređaju
DLP pokušaj ka spoljnoj zoni	Data Classification + Trust Zone + DLP + Audit	transfer se dozvoljava/blokira prema verzionisanoj politici bez čuvanja punog sadržaja
Attack-path mitigation	Asset + Trust Boundary + Vulnerability + Threat + Control	uklanjanje jedne slabosti/veze menja analitički put i ostavlja proverljiv trag odluke
Crypto rotacija kritičnog servisa	Crypto Inventory + Secrets/Certificates + Rotation + Audit	nova verzija se uvodi kontrolisano, stara se povlači tek nakon verifikacije i ne izlaže tajni materijal
Neočekivan internet exposure	Asset + Attack Surface + Vulnerability + Risk	nepoznati exposure dobija vlasnika, procenu i remediation/exception odluku
Rizičan transfer klasifikovanih podataka	Data Flow + Classification + Transfer Approval + DLP	transfer dobija determinističku allow/deny odluku uz minimalan audit metadata
Release bez dovoljno provenance dokaza	Supply Chain + Provenance + Vulnerability + Exception	release policy daje warn/block ili kontrolisan exception sa rokom i vlasnikom

10.2. Minimalni testni portfolio po timu

Vrsta	Minimalno očekivanje
Unit	policy, state tranzicije i bezbednosna pravila
Positive	dozvoljeni tok za ovlašćenog subjekta
Negative	nedozvoljeni pristup ili zloupotreba
Integration	authentication/authorization/secrets/audit granica
Regression	test za stvarno otkriven problem ili visokorizično ponašanje
Audit evidence	dokaz da značajan security događaj ostaje sledljiv
Contract/security boundary	accepted cross-team ugovor, security event ili policy format ima izvršiv test kompatibilnosti
Operational	clean clone, migracije i seed/demo scenario rade ponovljivo u dokumentovanom okruženju

10.3. Obavezni negativni scenariji

U zavisnosti od celine, tim bira relevantan podskup:

- korisnik pokušava pristup tuđem objektu;
- korisnik sa pogrešnim scope-om pokušava operaciju;
- istekla/revoked sesija pokušava pristup;
- privileged grant je istekao;
- MFA challenge je istekao ili ponovljen;
- revoked certificate/credential se koristi ponovo;
- security event je dupliran;
- evidence ili audit pristupa korisnik bez dozvole;
- dependency/vulnerability nalaz nema odgovarajući asset ili owner.

Predaja, dokumentacija i kriterijumi ocenjivanja

11

11.1. Obavezna dokumentacija

- odgovornost i trust granica projektne celine;
- glavni use-case-ovi i Tapis acceptance kriterijumi;
- threat model;
- javni API/message ugovori;
- ADR za značajne security odluke;
- uputstvo za lokalno pokretanje i testiranje;
- normalni i negativni demo scenario;
- poznata ograničenja i residual risk;
- spisak javnih ugovora, security događaja ili policy granica sa owner-om, consumer-ima i lifecycle stanjem;
- dokumentovane migracije, seed/demo podaci i potrebne konfiguracije promenljive bez tajnih vrednosti.

11.2. Ocenjivanje

Oblast	Šta se vrednuje
Funkcionalna ispravnost	obavezni use-case-ovi i stabilnost
Bezbednosni model	identitet, trust granice, least privilege i threat model
Autorizacija i zaštita podataka	server-side odluke, scope, ownership i klasifikacija
Bezbednosno testiranje	relevantni negativni i regression testovi
Auditabilnost	moгуćnost dokazivanja značajne promene ili security ishoda
Arhitektura i dizajn	Clean/SOLID, jasne granice i kontrolisane zavisnosti
Proces	Tapis, Git, PR, review, CI i kontinuitet rada
Integracija	stabilni ugovori i saradnja sa drugim timovima
Odbrana	student ume da objasni kontrolu, pretnju, test i residual risk

INDIVIDUALNA ODGOVORNOST.

Svaki student mora imati vidljiv doprinos i biti sposoban da objasni najmanje jedan bezbednosni use-case, jedan negativni scenario, relevantne testove i trust granicu svoje celine.

11.3. Nije prihvatljivo

- sopstveni algoritam za password hashing, encryption ili digitalni potpis;
- hard-coded credentials i tajne;
- autorizacija samo na UI nivou;
- endpoint-level role check bez object/scope provere kada je ona potrebna;
- beskonačna ili trajna privilegija bez poslovnog razloga;
- audit log sa lozinkama, tokenima ili secret vrednostima;
- bezbednosna kontrola bez negativnog testa;
- simulacija realnog napada nad spoljnim sistemom;
- zatvaranje vulnerability/risk stavke bez dokaza ili formalnog acceptance-a.

Rečnik ključnih pojmova

Pojam	Značenje u okviru projekta
Asset	informacioni resurs koji ima vlasnika, kritičnost i životni ciklus
Identity	ljudski ili servisni identitet koji učestvuje u bezbednosnoj odluci
Authentication	potvrda identiteta
Authorization	odluka da li subjekt sme da izvrši konkretnu akciju nad resursom
RBAC	autorizacija zasnovana na ulogama i dozvolama
Object-level authorization	provera prava nad konkretnim objektom/resursom
Step-up authentication	dodatna potvrda identiteta za osetljivu operaciju
Privileged Access	povišeni pristup koji nosi veći bezbednosni rizik
Secret	osetljiva vrednost kao API credential, password ili key material referenca
Service Identity	identitet aplikacije ili servisa, odvojen od ljudskog naloga
Security Event	dogadjaj relevantan za bezbednosno praćenje
Alert	signal da je detection rule prepoznao uslov za analizu
Security Incident	potvrđen ili dovoljno značajan bezbednosni problem koji zahteva odgovor
Evidence	kontrolisano sačuvan artefakt ili zapis relevantan za istragu
Threat	potencijalni uzrok neželjenog bezbednosnog ishoda
Vulnerability / Weakness	slabost koja može omogućiti ili povećati uticaj pretnje
Risk	kombinacija verovatnoće, uticaja i konteksta pretnje nad asset-om
Security Control	tehnička ili procesna mera koja smanjuje rizik
Residual Risk	rizik koji ostaje nakon primene kontrola
Audit	sledljiva evidencija značajne akcije, subjekta i ishoda
Trust Boundary	granica između zona različitog nivoa poverenja preko koje se tok mora eksplicitno analizirati
Retention Policy	verzionisano pravilo koliko dugo se klasa podataka čuva i pod kojim uslovima uklanja
Device Posture	skup vremenski ograničenih signala o bezbednosnom stanju uređaja

Pojam	Značenje u okviru projekta
DLP	kontrola detekcije i ograničavanja nedozvoljenog kretanja klasifikovanih podataka
Attack Path	analitički niz mogućih exposure/privilege koraka ka ciljnom asset-u, bez dokaza exploita
ADR	kratak zapis konteksta, odluke, alternativa i posledica arhitektonske odluke
Attack Surface	skup spolja ili međuzonski dostupnih tačaka kroz koje sistem može biti izložen bezbednosnom riziku
Provenance	sledljiv metadata dokaz o poreklu i procesu nastanka softverskog artefakta
Segregation of Duties	pravilo razdvajanja konfliktnog skupa privilegija ili odgovornosti između različitih subjekata
Cryptographic Posture	zbirna procena stanja kriptografskih sredstava, algoritama, isteka i migracionih rizika
ConsentRecord	zapis koji povezuje svrhu obrade, subjekt, status consent-a i period važenja
ServiceAccount	non-human identitet koji koristi servis, workload ili automatizovani proces
EvidencePackage	kontrolisan skup dokaza sa manifestom, integritetom i chain-of-custody metadata
Playbook	standardizovan skup koraka za bezbednosni scenario ili incident, sa odgovornostima i dokazima
CrownJewelAsset	kritičan asset/podatak/proces čiji kompromis ima visok poslovni ili bezbednosni uticaj
HumanRiskSignal	edukativni i agregirani indikator ponašanja, treninga ili nalaza koji zahteva dodatnu pažnju; nije etiketa pojedinca
ZeroTrustCapability	oblast zrelosti koja procenjuje eksplicitnu proveru identiteta, uređaja, konteksta i policy-ja
AutomationPolicy	pravilo koje definiše kada i kako je dozvoljena automatizovana security akcija